



Norma iso iec 27037 de 2012

Derecho Administrativo (Instituto Cultural Derechos Humanos)



messages.pdf_cover_qr_code_label

INTERNACIONAL ISO / IEC NORMA 27037

Primera edición
2012-10-15

Tecnología de la información. Técnicas de seguridad. Directrices para identificación, recopilación, adquisición y preservación de evidencia digital

Tecnología de la información. Técnicas de seguridad. Directrices para la identificación, recopilación, adquisición y conservación de pruebas digitales.

Número de referencia
ISO/IEC 27037:2012(E)



DOCUMENTO PROTEGIDO POR DERECHOS DE AUTOR © ISO/IEC 2012 Todos los derechos reservados. A menos que se especifique lo contrario, ninguna parte de esta publicación puede reproducirse ni utilizarse de ninguna forma ni por ningún medio, electrónico o mecánico, incluidas fotocopias y microfilmes, sin el permiso por escrito de ISO en la dirección a continuación o del organismo miembro de ISO en el país del solicitante ISO copyright office Case postale 56 □ CH-1211 Geneva 20 Tel. + 41 22 749 01 11 Fax + 41 22 749 09 47 E-mail copyright@iso.org Web www.iso.org Publicado En Suiza

Contenido

Prefacio	4
Introducción	5
1. Alcance	7
2. Referencia normativa	7
3. Términos y definiciones	8
4. Términos abreviados	10
5. Visión de conjunto	11
5.1 Contexto para recolectar evidencia digital	12
5.2 Principios de evidencia digital	12
5.3 Requisitos para el manejo de evidencia digital	12
5.3.1 General	12
5.3.2 Auditabilidad	13
5.3.3 Repetibilidad	13
5.3.4 Reproducibilidad	13
5.3.5 Justificabilidad	14
5.4 Procesos de manejo de evidencia digital	14
5.4.1 Descripción general	14
5.4.2 Identificación	15
5.4.3 Reolección	15
5.4.4 Adquisición	16
5.4.5 Preservación	17
6. Componentes clave de identificación, recopilación, adquisición y preservación de evidencia digital	17
6.1 Cadena de custodia	17
6.2 Precauciones en el lugar del incidente	18
6.2.1 General	18
6.2.2 Personal	19
6.2.3 Evidencia digital potencial	19
6.3 Funciones y responsabilidades	20
6.4 Competencia	20
6.5 Use cuidado razonable	21
6.6 Documentación	21
6.7 Instrucciones	22
6.7.1 General	22
6.7.2 Evidencia digital específica	22
6.7.3 Personal específico	23
6.7.4 Incidentes en tiempo real	24
6.7.5 Otra información informativa	24
6.8 Priorización de cobranza y adquisición	24
6.9 Preservación de evidencia digital potencial	25
6.9.1 Descripción general	25
6.9.2 Preservar evidencia digital potencial	25

6.9.3 Empaque de dispositivos digitales y evidencia digital potencial	26
6.9.4 Transporte de evidencia digital potencial.....	28
7. Instancias de identificación, recolección, adquisición y conservación.	28
7.1 Computadoras, dispositivos periféricos y medios de almacenamiento digital.	28
7.1.1 Identificación.....	28
7.1.2 Recolección.....	31
7.1.3 Adquisición	35
7.1.3.2 Apagado de dispositivos digitales.....	38
7.1.4 Preservación.....	40
7.2 Dispositivos en red	40
7.2.1 Identificación.....	40
7.2.2 Recolección, adquisición y conservación.	42
7.3 Recolección, adquisición y preservación de CCTV	45
Anexo A (informativo)	48
Anexo B (informativo)	51
Bibliografía.....	52

Prefacio

ISO (la Organización Internacional de Normalización) e IEC (la Comisión Electrotécnica Internacional) forman el sistema especializado para la estandarización mundial. Los organismos nacionales que son miembros de ISO o IEC participan en el desarrollo de Normas Internacionales a través de comités técnicos establecidos por la organización respectiva para ocuparse de campos particulares de actividad técnica. Los comités técnicos de ISO e IEC colaboran en campos de interés mutuo. Otras organizaciones internacionales, gubernamentales y no gubernamentales, en colaboración con ISO e IEC, también participan en el trabajo. En el campo de la tecnología de la información, ISO e IEC han establecido un comité técnico conjunto, ISO / IEC JTC 1.

Las Normas Internacionales están redactadas de acuerdo con las reglas dadas en las Directivas ISO / IEC, Parte 2.

La tarea principal del comité técnico conjunto es preparar Normas Internacionales. Los proyectos de normas internacionales adoptados por el comité técnico conjunto se distribuyen a los organismos nacionales para su votación. La publicación como norma internacional requiere la aprobación de al menos el 75% de los organismos nacionales que emiten un voto.

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan estar sujetos a derechos de patente. ISO e IEC no serán responsables de identificar ninguno o todos los derechos de patente.

ISO / IEC 27037 fue preparado por el Comité Técnico Conjunto ISO / IEC JTC 1, Tecnología de la información, Subcomité SC 27, Técnicas de seguridad de TI.

Introducción

Esta Norma Internacional proporciona pautas para actividades específicas en el manejo de evidencia digital potencial; Estos procesos son: identificación, recopilación, adquisición y preservación de evidencia digital potencial. Estos procesos son necesarios en una investigación diseñada para mantener la integridad de la evidencia digital, una metodología aceptable para obtener evidencia digital que contribuirá a su admisibilidad en acciones legales y disciplinarias, así como en otras instancias requeridas. Esta Norma Internacional también proporciona pautas generales para la recopilación de evidencia no digital que pueden ser útiles en la etapa de análisis de la evidencia digital potencial.

Esta Norma Internacional tiene la intención de proporcionar orientación a las personas responsables de la identificación, recopilación, adquisición y preservación de evidencia digital potencial. Estas personas incluyen Digital Responder First Responders (DEFR), Digital Evidence Specialists (DESS), especialistas en respuesta a incidentes y gerentes forenses de laboratorio. Esta Norma Internacional garantiza que las personas responsables gestionen la evidencia digital potencial de maneras prácticas que sean aceptables en todo el mundo, con el objetivo de facilitar la investigación que involucre dispositivos digitales y evidencia digital de manera sistemática e imparcial, preservando su integridad y autenticidad.

Esta Norma Internacional también tiene la intención de informar a los tomadores de decisiones que necesitan determinar la confiabilidad de la evidencia digital que se les presenta. Es aplicable a las organizaciones que necesitan proteger, analizar y presentar evidencia digital potencial. Es relevante para los organismos de formulación de políticas que crean y evalúan procedimientos relacionados con la evidencia digital, a menudo como parte de un conjunto de evidencia más amplio.

La evidencia digital potencial a la que se hace referencia en esta Norma Internacional puede provenir de diferentes tipos de dispositivos digitales, redes, bases de datos, etc. Se refiere a datos que ya están en formato digital. Esta norma internacional no intenta cubrir la conversión de datos analógicos a formato digital.

Debido a la fragilidad de la evidencia digital, es necesario llevar a cabo una metodología aceptable para garantizar la integridad y autenticidad de la potencial evidencia digital. Esta Norma Internacional no exige el uso de herramientas o métodos particulares. Los componentes clave que brindan credibilidad en la investigación son la metodología aplicada durante el proceso y las personas calificadas para realizar las tareas especificadas en la metodología. Esta Norma Internacional no aborda la metodología para procedimientos legales, procedimientos disciplinarios y otras acciones relacionadas en el manejo de evidencia digital potencial que están fuera del alcance de identificación, recopilación, adquisición y preservación.

La aplicación de esta Norma Internacional requiere el cumplimiento de las leyes, normas y reglamentos nacionales. No debe reemplazar los requisitos legales específicos de ninguna jurisdicción. En cambio, puede servir como una guía práctica para cualquier DEFR o DES en investigaciones que involucren evidencia digital potencial. No se extiende al análisis de evidencia digital y no reemplaza los requisitos específicos de jurisdicción que se refieren a asuntos como la admisibilidad, la ponderación de evidencia, la relevancia y otras limitaciones controladas judicialmente sobre el uso de evidencia digital potencial en los tribunales de justicia. Esta Norma Internacional puede ayudar a facilitar el posible intercambio de evidencia digital entre jurisdicciones. Para mantener la integridad de la evidencia digital, los usuarios de esta Norma Internacional deben adaptar y modificar los procedimientos descritos en esta Norma Internacional de acuerdo con los requisitos legales de evidencia de la jurisdicción específica.

Aunque esta Norma Internacional no incluye la preparación forense, la preparación forense adecuada puede apoyar en gran medida el proceso de identificación, recopilación, adquisición y

preservación de evidencia digital. La preparación forense es el logro de un nivel apropiado de capacidad por parte de una organización para poder identificar, recopilar, adquirir, preservar, proteger y analizar evidencia digital. Mientras que los procesos y actividades descritos en esta Norma Internacional son esencialmente medidas reactivas utilizadas para investigar un incidente después de que ocurrió, la preparación forense es un proceso proactivo de intentar planificar tales eventos.

Esta norma internacional complementa las normas ISO / IEC 27001 e ISO / IEC 27002, y en particular los requisitos de control relacionados con la posible adquisición de evidencia digital al proporcionar orientación de implementación adicional. Además, esta Norma Internacional tendrá aplicaciones en contextos independientes de ISO / IEC 27001 e ISO / IEC 27002. Esta Norma Internacional debe leerse junto con otras normas relacionadas con la evidencia digital y la investigación de incidentes de seguridad de la información.

Tecnología de la información. Técnicas de seguridad. Directrices para la identificación, recopilación, adquisición y conservación de pruebas digitales.

1. Alcance

Esta Norma Internacional proporciona pautas para actividades específicas en el manejo de evidencia digital, que son la identificación, recolección, adquisición y preservación de evidencia digital que puede ser de valor probatorio. Esta Norma Internacional proporciona orientación a las personas con respecto a situaciones comunes encontradas durante el proceso de manejo de evidencia digital y ayuda a las organizaciones en sus procedimientos disciplinarios y facilita el intercambio de evidencia digital potencial entre jurisdicciones.

Esta norma internacional brinda orientación para los siguientes dispositivos y / o funciones que se utilizan en diversas circunstancias:

- ☐ Medios de almacenamiento digital utilizados en computadoras estándar como discos duros, disquetes, discos ópticos y magnetoópticos, dispositivos de datos con funciones similares,
- ☐ Teléfonos móviles, asistentes digitales personales (PDA), dispositivos electrónicos personales (PED), tarjetas de memoria,
- ☐ Sistemas de navegación móvil,
- ☐ Cámaras digitales fijas y de video (incluyendo CCTV),
- ☐ Computadora estándar con conexiones de red,
- ☐ Redes basadas en TCP / IP y otros protocolos digitales, y
- ☐ Redes basadas en TCP / IP y otros protocolos digitales, y

NOTE 1 La lista de dispositivos anterior es una lista indicativa y no exhaustiva.

NOTE 2 Las circunstancias incluyen los dispositivos anteriores que existen en varias formas. Por ejemplo, un sistema automatizado puede incluir un sistema de navegación móvil, almacenamiento de datos y sistema sensorial.

2. Referencia normativa

Los siguientes documentos referenciados son indispensables para la aplicación de este documento. Para las referencias con fecha, sólo se aplica la edición citada. Para referencias sin fecha, se aplica la última edición del documento referenciado (incluidas las enmiendas).

ISO/TR 15801, *Gestión de documentos - Información almacenada electrónicamente - Recomendaciones para*

confiabilidad y confiabilidad

ISO/IEC 17020, *Evaluación de la conformidad: requisitos para el funcionamiento de diversos tipos de organismos que realizan inspecciones*

ISO/IEC 17025:2005, *Requisitos generales para la competencia de los laboratorios de ensayo y calibración.*

ISO/IEC 27000, *Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de seguridad de la información - Descripción general y vocabulario*

3. Términos y definiciones

A los fines de este documento, se aplican los términos y definiciones en ISO / IEC 27000, ISO / IEC 17020, ISO / IEC 17025 e ISO / TR 15801, así como lo siguiente.

3.1 proceso de adquisición de crear una copia de datos dentro de un conjunto definido

NOTA El producto de una adquisición es una posible copia de evidencia digital.

3.2 área de espacio asignada en medios digitales, incluida la memoria primaria, que se usa para el almacenamiento de datos, incluidos los metadatos

3.3 proceso de recolección de recolección de elementos físicos que contienen evidencia digital potencial

3.4 dispositivo electrónico equipo electrónico utilizado para procesar o almacenar datos digitales

3.5 información o datos de evidencia digital, almacenados o transmitidos en forma binaria que se puede confiar como evidencia

3.6 copia de evidencia digital; copia de la evidencia digital que se ha producido para mantener la confiabilidad de la evidencia al incluir tanto la evidencia digital como los medios de verificación en los que el método de verificación puede integrarse o ser independiente de las herramientas utilizadas para hacer la verificación

3.7 Primer Responsable en Evidencia Digital DEFR; Persona autorizada, capacitada y calificada para actuar primero en una escena de incidente en la realización de la recolección y adquisición de evidencia digital con la responsabilidad de manejar esa evidencia

NOTA La autoridad, la capacitación y la calificación son los requisitos esperados necesarios para producir evidencia digital confiable, pero las circunstancias individuales pueden hacer que una persona no cumpla con los tres requisitos. En este caso, la ley local, la política organizacional y las circunstancias individuales deben considerarse.

3.8 Especialista en evidencia digital DES; Individuo que puede llevar a cabo las tareas de un DEFR y tiene conocimientos especializados, habilidades y capacidades para manejar una amplia gama de problemas técnicos.

NOTA: Un DES puede tener habilidades de nicho adicionales, por ejemplo, adquisición de red, adquisición de RAM, software de sistema operativo o conocimiento de mainframe.

3.9 dispositivo de almacenamiento digital en el que se pueden grabar datos digitales

[Adaptado de ISO/IEC 10027:1990]

3.10 entorno seguro de la instalación de preservación de evidencia o un lugar donde se almacena la evidencia recopilada o adquirida

NOTA Una instalación de preservación de evidencia no debe exponerse a campos magnéticos, polvo, vibraciones, humedad o cualquier otro elemento ambiental (como temperatura o humedad extremas) que puedan dañar la evidencia digital potencial dentro de la instalación.

3.11 valor hash; cadena de bits que es la salida de una función hash

[ISO/IEC 10118-1:2000]

3.12 proceso de identificación que implica la búsqueda, el reconocimiento y la documentación de evidencia digital potencial

3.13 imagen proceso de crear una copia bit a bit de medios de almacenamiento digital

NOTA La copia bit a bit también se denomina copia física.

EJEMPLO Al generar imágenes de un disco duro, el DEFR también copiará los datos que se hayan eliminado.

3.14 dispositivo periférico conectado a un dispositivo digital para ampliar su funcionalidad

3.15 proceso de preservación para mantener y salvaguardar la integridad y / o la condición original de la evidencia digital potencial

3.16 propiedad de confiabilidad del comportamiento y resultados previstos consistentes

[ISO/IEC 27000:2009]

3.17 repetibilidad; propiedad de un proceso realizado para obtener los mismos resultados de prueba en el mismo entorno de prueba (misma computadora, disco duro, modo de operación, etc.)

3.18 reproducibilidad; propiedad de un proceso para obtener los mismos resultados de prueba en un entorno de prueba diferente (computadora, disco duro, operador, etc.)

3.19 expoliación; acto de hacer o permitir cambios en la evidencia digital potencial que disminuye su valor probatorio

3.20 hora del sistema generada por el reloj del sistema y utilizada por el sistema operativo, no la hora calculada por el sistema operativo

3.21 manipulación; acto de hacer o permitir deliberadamente cambios en la evidencia digital (es decir, despojo intencional o intencional)

3.22 marca de tiempo; parámetro de variante de tiempo que denota un punto en el tiempo con respecto a una referencia de tiempo común [ISO/IEC 11770-1:1996]

3.23 espacio sin asignar; área en medios digitales, incluida la memoria primaria, que no ha sido asignada por el sistema operativo y que está disponible para el almacenamiento de datos, incluidos los metadatos.

3.24 confirmación de validación, mediante la provisión de pruebas objetivas, de que se han cumplido los requisitos para un uso o aplicación específica

[ISO/IEC 27004:2009]

3.25 función de función de verificación que se utiliza para verificar que dos conjuntos de datos son idénticos

NOTA 1 No hay dos conjuntos de datos no idénticos que produzcan una coincidencia idéntica a partir de una función de verificación.

NOTA 2 Las funciones de verificación se implementan comúnmente utilizando funciones hash como MD5, SHA1, etc., pero se pueden usar otros métodos.

3.26 datos de datos volátiles que son especialmente propensos a cambiar y pueden modificarse fácilmente

NOTA Un cambio puede ser desconectar la alimentación o pasar a través de un campo magnético. Los datos volátiles también incluyen datos que cambian a medida que cambia el estado del sistema. Los ejemplos incluyen datos almacenados en RAM y direcciones IP dinámicas.

4. Términos abreviados

AVI	Audio Video Intercalar
CCTV	Circuito cerrado de televisión
CD	Disco compacto
DNA	Ácido desoxirribonucleico
DEFR	Primer responsable de evidencia digital
DES	Especialista en evidencia digital
DVD	Video digital / Disco versátil
ESN	Número de serie electrónico
GPS	Sistema de Posicionamiento Global

GSM	Sistema global para comunicación móvil
IMEI	Identificación Internacional del Equipo Móvil
IP	Protocolo de Internet
ISIRT	Equipo de respuesta a incidentes de seguridad de la información
LAN	Red de área local
MD5	Algoritmo de resumen de mensaje 5
MP3	MPEG Audio Layer 3
MPEG	Audio Layer 3
NAS	Almacenamiento conectado a la red
PDA	Asistente personal digital
PED	Dispositivo electrónico personal
PIN	Número de identificación personal
PUK	PIN Tecla de desbloqueo
RAID	Matriz redundante de discos independientes
RAM	Memoria de acceso aleatorio
RFID	Identificación de frecuencia de radio
SAN	Red de área de almacenamiento
SHA	Algoritmo de hash seguro
SIM	Módulo de Identidad del Suscriptor
USB	Universal Serial Bus
UPS	Fuente de poder ininterrumpible
USIM	Módulo universal de identidad del suscriptor
UV	Ultravioleta
Wi-Fi	Fidelidad inalámbrica

5. Visión de conjunto

5.1 Contexto para recolectar evidencia digital

Se puede requerir evidencia digital para su uso en varios escenarios distintos, cada uno de los cuales tiene un equilibrio diferente entre los impulsores de la calidad de la evidencia, la puntualidad del análisis, la restauración del servicio y el costo de la recolección de evidencia digital. Por lo tanto, se requerirá que las organizaciones tengan un proceso de priorización que identifique las necesidades y equilibre la calidad evidencia, la puntualidad y la restauración del servicio antes de asignar recursos de DEFR. Un proceso de priorización implica llevar a cabo una evaluación del material disponible para determinar el posible valor probatorio y el orden en que se debe recopilar, adquirir o preservar la evidencia digital potencial. La priorización se lleva a cabo para minimizar el riesgo de que la evidencia digital potencial se eche a perder y maximizar el valor probatorio de la evidencia digital potencial recopilada.

5.2 Principios de evidencia digital

En la mayoría de las jurisdicciones y organizaciones, la evidencia digital se rige por tres principios fundamentales: relevancia, fiabilidad y suficiencia. Estos tres principios son importantes para todas las investigaciones, no solo para que las pruebas digitales sean admisibles en los tribunales. La evidencia digital es relevante cuando se trata de probar o refutar un elemento del caso específico que se está investigando. Aunque la definición detallada de "confiable" varía entre las jurisdicciones, el significado general del principio, "para garantizar que la evidencia digital es lo que pretende ser", es ampliamente aceptado. No siempre es necesario que el DEFR recopile todos los datos o haga una copia completa de la evidencia digital original. En muchas jurisdicciones, el concepto de suficiencia significa que el DEFR necesita recopilar suficiente evidencia digital potencial para permitir que los elementos del asunto sean examinados o investigados adecuadamente. Comprender este concepto es importante para que el DEFR priorice el esfuerzo adecuadamente cuando el tiempo o el costo son una preocupación.

NOTA El DEFR debe garantizar que la recopilación de evidencia digital potencial esté de acuerdo con las leyes y regulaciones jurisdiccionales locales, según lo requieran las circunstancias específicas.

Todos los procesos a ser utilizados por el DEFR y el DES deberían haber sido validados antes de su uso. Si la validación se lleva a cabo externamente, el DEFR o DES debe verificar que la validación sea apropiada para su uso específico de los procesos y el entorno y las circunstancias en las que los procesos están a punto de usarse. El DEFR o DES también debe:

- a) documentar todas las acciones;
- b) determinar y aplicar un método para establecer la precisión y confiabilidad de la posible copia de evidencia digital en comparación con la fuente original; y
- c) reconocer que el acto de preservación de la evidencia digital potencial no siempre puede ser no intrusivo.

5.3 Requisitos para el manejo de evidencia digital

5.3.1 General

Los principios establecidos en la cláusula 5.2 anterior se pueden cumplir de la siguiente manera:

□ **Relevancia:** debería ser posible demostrar que el material adquirido es relevante para la investigación, es decir, que contiene información valiosa para ayudar a la investigación del incidente particular y que hay una buena razón para que se haya adquirido. A través de la auditoría y la justificación, el DEFR debería poder describir los procedimientos seguidos y explicar cómo se tomó la decisión de adquirir cada artículo.

□ **Confiabilidad:** Todos los procesos utilizados en el manejo de evidencia digital potencial deben ser auditables y repetibles. Los resultados de la aplicación de tales procesos deben ser reproducibles.

□ **Suficiencia:** El DEFR debería haber tenido en cuenta que se ha reunido suficiente material para permitir una investigación adecuada. El DEFR debería ser capaz, mediante auditoría y justificación, de dar una indicación de cuánto material, en total, se consideró y los procedimientos utilizados para decidir cuánto y qué material adquirir.

NOTA Los materiales pueden recopilarse mediante actividades de adquisición y / o recolección.

Existen cuatro aspectos clave en el manejo de evidencia digital: auditabilidad, justificación y repetibilidad o reproducibilidad dependiendo de las circunstancias particulares.

5.3.2 Auditabilidad

Debería ser posible que un asesor independiente u otras partes interesadas autorizadas evalúen las actividades realizadas por un DEFR y un DES. Esto será posible al documentar adecuadamente todas las acciones tomadas. El DEFR y el DES deberían poder justificar el proceso de toma de decisiones al seleccionar un curso de acción dado. Los procesos realizados por un DEFR y DES deben estar disponibles para una evaluación independiente para determinar si se siguió un método, técnica o procedimiento científico apropiado.

5.3.3 Repetibilidad

La repetibilidad se establece cuando se producen los mismos resultados de la prueba en las siguientes condiciones:

Usar el mismo procedimiento y método de medición;

Usar los mismos instrumentos y bajo las mismas condiciones; y

Se puede repetir en cualquier momento después de la prueba original.

Un DEFR adecuadamente capacitado y experimentado debe ser capaz de llevar a cabo todos los procesos descritos en la documentación y llegar a los mismos resultados, sin orientación o interpretación. El DEFR debe ser consciente de que puede haber circunstancias en las que no sea posible repetir la prueba, p. Ej. cuando un disco duro original se ha copiado y vuelto a usar, o cuando un elemento involucra memoria volátil. En este caso, el DEFR debe garantizar que el proceso de adquisición sea confiable. Para lograr la repetibilidad, el control de calidad y la documentación del proceso deben estar en su lugar.

5.3.4 Reproducibilidad

La reproducibilidad se establece cuando se producen los mismos resultados de la prueba en las siguientes condiciones:

- ☐ Usando el mismo método de medición;
- ☐ Usar diferentes instrumentos y bajo diferentes condiciones; y
- ☐ Se puede reproducir en cualquier momento después de la prueba original.

Las necesidades de reproducción de resultados varían según las jurisdicciones y circunstancias, por lo que el DEFR o la persona que realiza la reproducción deberá ser informada sobre las condiciones aplicables.

5.3.5 Justificabilidad

El DEFR debe poder justificar todas las acciones y métodos utilizados en el manejo de la evidencia digital potencial. La justificación se puede lograr demostrando que la decisión fue la mejor opción para obtener toda la evidencia digital potencial. Otro DEFR o DES también podría demostrar esto reproduciendo o validando con éxito las acciones y los métodos utilizados.

Es en el mejor interés de la organización individual emplear un DEFR o DES que posea las habilidades y competencias básicas como se describe en el Anexo A de esta Norma Internacional. Esto asegurará que se sigan los procesos y procedimientos correctos al manejar evidencia digital potencial para asegurar la preservación eventual de evidencia digital que pueda tener valor probatorio. Esto también asegurará que las organizaciones puedan usar la evidencia digital potencial, por ejemplo, en sus procedimientos disciplinarios o para facilitar el intercambio de evidencia digital potencial entre jurisdicciones.

NOTA La competencia descrita en el Anexo A está limitada a la función DEFR que está alineada con el rol de DES como se define en la Cláusula 3.8.

5.4 Procesos de manejo de evidencia digital

5.4.1 Descripción general

Aunque el proceso completo de manejo de evidencia digital incluye otras actividades (es decir, presentación, eliminación, etc.), el alcance de esta Norma Internacional se relaciona solo con el proceso de manejo inicial que consiste en la identificación, recolección, adquisición y preservación de evidencia digital potencial.

La evidencia digital puede ser de naturaleza frágil. Puede ser alterado, manipulado o destruido a través de un manejo o examen incorrecto. Los manejadores de evidencia digital deben ser competentes para identificar y gestionar los riesgos y las consecuencias de posibles cursos de acción cuando se trata de evidencia digital. Si no se manejan los dispositivos digitales de manera adecuada, es posible que la evidencia digital potencial contenida en esos dispositivos digitales sea inutilizable.

El DEFR y el DES deben seguir procedimientos documentados para garantizar que se mantenga la integridad y confiabilidad de la evidencia digital potencial. Los procedimientos deben incluir pautas de manejo de fuentes de evidencia digital potencial y deben incluir los siguientes principios fundamentales:

- ☐ Minimice el manejo del dispositivo digital original o la evidencia digital potencial;

- ☐ Tenga en cuenta los cambios y documente las acciones tomadas (en la medida en que un experto pueda formar un
opinión sobre fiabilidad);
- ☐ Cumplir con las reglas locales de evidencia; y

DE El DEFR y el DES no deben tomar acciones más allá de su competencia.

Al cumplir con los principios y requisitos fundamentales del manejo de evidencia digital potencial, la evidencia debe preservarse. Específicamente en el caso de que se hicieran cambios inevitables, todas las acciones y razones deben documentarse. Cada proceso de manejo de evidencia digital, es decir, identificación, recopilación, adquisición y preservación, se analiza con más detalle en las cláusulas a continuación.

5.4.2 Identificación

La evidencia digital está representada en forma física y lógica. La forma física incluye la representación de datos dentro de un dispositivo tangible. La forma lógica de la evidencia digital potencial se refiere a la representación virtual de datos dentro de un dispositivo.

El proceso de identificación implica la búsqueda, el reconocimiento y la documentación de evidencia digital potencial. El proceso de identificación debe identificar los medios de almacenamiento digital y los dispositivos de procesamiento que pueden contener evidencia digital potencial relevante para el incidente. Este proceso también incluye una actividad para priorizar la recopilación de evidencia en función de su volatilidad. La volatilidad de los datos debe identificarse para garantizar el orden correcto de los procesos de recopilación y adquisición para minimizar el daño a la evidencia digital potencial y obtener la mejor evidencia. Además, el proceso debe identificar la posibilidad de evidencia digital potencial oculta. El DEFR y el DES deben ser conscientes de que no todos los tipos de medios de almacenamiento digital pueden identificarse y ubicarse fácilmente, por ejemplo, computación en la nube, NAS y SAN; todos agregan un componente virtual al proceso de identificación.

El DEFR debería llevar a cabo una búsqueda exhaustiva de artículos que puedan contener evidencia digital potencial. Los diferentes tipos de dispositivos digitales que pueden contener evidencia digital potencial pueden pasarse por alto fácilmente (por ejemplo, debido a su pequeño tamaño), disfrazarse o mezclarse entre otros materiales irrelevantes.

Las cláusulas 6.1 y 6.6 proporcionan más información sobre los aspectos de la cadena de custodia, empaque y etiquetado de la identificación de evidencia digital. La cláusula 7 especifica pautas relevantes para casos específicos de identificación, recopilación, adquisición y preservación de evidencia digital.

5.4.3 Recolección

Una vez que se identifican los dispositivos digitales que pueden contener evidencia digital potencial, el DEFR y el DES deben decidir si se recopilan o adquieren durante el siguiente proceso. Hay varios factores de decisión para esto, que se discuten con más detalle en la Cláusula 7. La decisión debe basarse en las circunstancias.

La recopilación es un proceso en el proceso de manejo de evidencia digital donde los dispositivos que pueden contener evidencia digital potencial se eliminan de su ubicación original a un laboratorio u otro entorno controlado para su posterior adquisición y análisis. Los dispositivos que contienen evidencia digital potencial pueden estar en uno de dos

estados: cuando el sistema está encendido o cuando el sistema está apagado. Se requieren diferentes enfoques y herramientas, dependiendo del estado del dispositivo. Los procedimientos locales pueden aplicarse a los enfoques y herramientas utilizados para el proceso de recolección.

Este proceso incluye documentar todo el enfoque, así como el embalaje de estos dispositivos antes del transporte. Es importante que DEFR y DES recopilen cualquier material que pueda estar relacionado con la información digital potencial (por ejemplo, papel con contraseñas anotadas, bases y conectores de alimentación para dispositivos de sistema integrados). La evidencia digital potencial puede perderse o dañarse si no se aplica un cuidado razonable. El DEFR y el DES deberían adoptar el mejor método de recolección posible basado en la situación, el costo y el tiempo, y documentar la decisión de usar un método en particular.

NOTA 1 No siempre se recomienda la eliminación de los medios de almacenamiento digital y el DEFR debe asegurarse de que son competentes para eliminar los medios de almacenamiento, y reconocer cuándo es apropiado y permitido hacerlo.

NOTA 2 Los detalles sobre dispositivos digitales no recopilados deben documentarse con justificación para su exclusión, de acuerdo con los requisitos de la jurisdicción aplicable.

5.4.4 Adquisición

El proceso de adquisición implica producir una copia de evidencia digital (por ejemplo, disco duro completo, partición, archivos seleccionados) y documentar los métodos utilizados y las actividades realizadas. El DEFR debe adoptar un método de adquisición adecuado basado en la situación, el costo y el tiempo, y documentar la decisión de usar un método o herramienta particular de manera adecuada.

Los métodos utilizados para adquirir evidencia digital potencial deben estar claramente documentados en detalle y, en la medida de lo posible, ser reproducibles o verificables por un DEFR competente. Un DEFR o DES debe adquirir la evidencia digital potencial de la manera menos intrusiva para evitar introducir cambios cuando sea posible. Al llevar a cabo este proceso, el DEFR debe considerar el método más apropiado para usar. Si el proceso resulta en una alteración inevitable de los datos digitales, las actividades realizadas deben documentarse para dar cuenta de los cambios en los datos.

El método de adquisición utilizado debe producir una copia de evidencia digital de la evidencia digital potencial o dispositivos digitales que puedan contener evidencia digital potencial. Tanto la fuente original como la copia de evidencia digital deben verificarse con una función de verificación comprobada (probada con precisión en ese momento) que sea aceptable para la persona que utilizará la evidencia. La fuente original y cada copia de evidencia digital debe producir la misma salida de función de verificación.

En circunstancias en las que el proceso de verificación no se puede realizar, por ejemplo, al adquirir un sistema en ejecución, la copia original contiene sectores de error o el período de tiempo de adquisición es limitado. En tales casos, el DEFR debe usar el mejor método posible disponible y ser capaz de justificar y defender la selección del método. Si la imagen no se puede verificar, entonces esto debe documentarse y justificarse. Si es necesario, el método de adquisición utilizado debería poder obtener el espacio asignado y no asignado.

NOTA 1 Cuando el proceso de verificación no se puede realizar en la fuente completa debido a errores en la fuente, entonces se puede usar la verificación usando aquellas partes de la fuente que pueden leerse de manera confiable.

Puede haber casos en los que no sea factible o permisible crear una copia de evidencia digital de una fuente de evidencia, como cuando la fuente es demasiado grande. En estos casos, un DEFR puede realizar una adquisición lógica, que se dirige solo a tipos de datos específicos, directorios o ubicaciones. Esto generalmente tiene lugar a nivel de archivo y partición. Durante la adquisición lógica, se pueden copiar archivos activos y espacio asignado no basado en archivos en los medios de almacenamiento digital; los archivos eliminados y el espacio no asignado no se pueden copiar, según el método utilizado. Otras instancias donde este método puede ser útil son cuando están involucrados sistemas de misión crítica que no se pueden apagar.

NOTA 2 Algunas jurisdicciones pueden requerir un tratamiento especial para los datos; por ejemplo, séllelo en presencia del propietario de los datos. El sellado debe realizarse de acuerdo con los requisitos locales (legislativos y de procedimiento).

5.4.5 Preservación

Se debe preservar la evidencia digital potencial para garantizar su utilidad en la investigación. Es importante proteger la integridad de la evidencia. El proceso de preservación implica la salvaguarda de evidencia digital potencial y dispositivos digitales que pueden contener evidencia digital potencial de manipulación o despojo. El proceso de preservación debe iniciarse y mantenerse a lo largo de los procesos de manejo de evidencia digital, comenzando por la identificación de los dispositivos digitales que contienen evidencia digital potencial.

En el mejor de los casos, no debe haber ninguna separación de los datos en sí ni de ningún metadato asociado con ellos (por ejemplo, marcas de fecha y hora). El DEFR debería poder demostrar que la evidencia no ha sido modificada desde que fue recolectada o adquirida, o proporcionar la justificación y las acciones documentadas si se hicieron cambios inevitables.

NOTA En algunos casos, la confidencialidad de la evidencia digital potencial es un requisito, ya sea un requisito comercial o un requisito legal (por ejemplo, privacidad). La evidencia digital potencial debe preservarse de manera que se garantice la confidencialidad de los datos.

6. Componentes clave de identificación, recopilación, adquisición y preservación de evidencia digital.

6.1 Cadena de custodia

En cualquier investigación, el DEFR debería poder contabilizar todos los datos y dispositivos adquiridos en el momento en que está bajo la custodia del DEFR. El registro de la cadena de custodia es un documento que identifica la cronología del movimiento y el manejo de la evidencia digital potencial. Debe instituirse a partir del proceso de recolección o adquisición. Esto generalmente se logrará rastreando el historial del artículo desde el momento en que fue identificado, recogido o adquirido por el equipo investigador hasta el estado y ubicación actuales.

El registro de la cadena de custodia es un documento o una serie de documentos relacionados que detalla la cadena de custodia y los registros responsables de manejar la evidencia digital potencial, ya sea en forma de datos digitales u otros formatos (como notas en papel). El propósito de mantener un registro de cadena de custodia es permitir la identificación de acceso y movimiento de evidencia digital potencial en cualquier momento dado. El registro de la cadena de custodia en sí puede comprender más de un documento, p. para evidencia digital potencial, debe haber un documento contemporáneo que registre la

adquisición de datos digitales a un dispositivo en particular, el movimiento de ese dispositivo y la documentación que registre extractos o copias posteriores de evidencia digital potencial para su análisis u otros fines. El registro de la cadena de custodia debe contener la siguiente información como mínimo:

- ☐ Identificador único de evidencia;
- ☐ Quién accedió a la evidencia y la hora y el lugar en que tuvo lugar;
- ☐ Quién verificó la evidencia dentro y fuera de la instalación de preservación de evidencia y cuándo sucedió;
- ☐ Por qué se verificó la evidencia (qué caso y el propósito) y la autoridad pertinente, si corresponde; y
- ☐ Cualquier cambio inevitable en la evidencia digital potencial, así como el nombre de la persona responsable y la justificación para la introducción del cambio.

La cadena de custodia se debe mantener durante toda la vida útil de la evidencia y preservarse durante un cierto período de tiempo después del final de la vida útil de la evidencia; este período de tiempo se puede establecer de acuerdo con las jurisdicciones locales de la recopilación y aplicación de evidencia. Debe establecerse desde el momento en que se adquieren los dispositivos digitales y / o la evidencia digital potencial y no debe verse comprometida.

NOTA Algunas jurisdicciones pueden tener requisitos especiales con respecto a la cadena de custodia. El DEFR debe cumplir con esos requisitos.

6.2 Precauciones en el lugar del incidente.

6.2.1 General

El DEFR debe realizar actividades para asegurar y proteger la ubicación de la evidencia digital potencial tan pronto como lleguen al sitio. Las actividades deben apoyar lo siguiente, sujeto a la ley local:

- ☐ Asegure y tome el control del área que contiene los dispositivos;
- ☐ Determinar quién es el individuo a cargo de la ubicación;
- ☐ Asegúrese de que las personas se alejen de los dispositivos y las fuentes de alimentación;
- ☐ Documente a cualquier persona que tenga acceso a la ubicación y a cualquiera que tenga una razón para involucrarse en la escena del incidente;
- ☐ Si el dispositivo está encendido, no lo apague y si el dispositivo está apagado, no lo encienda;
- ☐ Si es posible, documente (por ejemplo, boceto, fotografía o video) la escena, todos los componentes y cables en su posición original. Si no hay una cámara y / o cámara de video disponible, dibuje un plan de bosquejo del sistema y etiquete los puertos y cables para que el sistema pueda ser validado y reconstruido en una fecha posterior; y

☐ Si está permitido, busque en las áreas elementos como notas adhesivas, diarios, papeles, computadoras portátiles o manuales de hardware y software con detalles cruciales sobre los dispositivos, como contraseñas y PIN.

NOTA 1 Algunas jurisdicciones pueden tener requisitos especiales para la admisión de fotografías y pruebas de video. El DEFR debe cumplir con esos requisitos.

NOTA 2 Los DEFR deben ser conscientes de que la evidencia digital potencial puede no estar siempre en ubicaciones obvias, como el almacenamiento distribuido o virtualizado.

El DEFR debe conocer primero todos los riesgos involucrados en la realización de todos los procesos durante la investigación. Se debe considerar proteger al personal y la evidencia digital potencial en la escena del incidente.

6.2.2 Personal

Es importante realizar una evaluación de riesgos con respecto a la seguridad del personal antes de comenzar el proceso, ya que la seguridad del personal involucrado en el proceso es vital. Las cuestiones que se deben considerar al evaluar los riesgos para el personal incluyen, entre otras, las siguientes:

- ☐ ¿Estarán presentes los individuos investigados? Si están presentes, ¿tienen propensión a la violencia?
- ☐ ¿A qué hora del día se llevará a cabo la operación?
- ☐ ¿Se puede aislar la escena del incidente de los espectadores?
- ☐ ¿Hay armas en el área?
- ☐ ¿Hay algún peligro físico para las personas presentes?
- ☐ ¿Se ha configurado algo en las proximidades, incluido el dispositivo, para causar daños físicos si se maneja de manera inapropiada, p. trampa oculta?
- ☐ ¿El material a recolectar tiene alguna probabilidad de causar daño psicológico u ofensa?
- ☐ ¿La escena del incidente puede considerarse insegura?
- ☐ ¿El área circundante tiene un impacto en el potencial de riesgo?

6.2.3 Evidencia digital potencial

El DEFR debe tener cuidado al usar una herramienta específica para recopilar o adquirir evidencia digital potencial. No calcular los riesgos antes de actuar puede conducir a la pérdida de parte o la totalidad de la evidencia digital potencial debido a la tecnología aplicada durante la recopilación o adquisición. Se deben evaluar los riesgos para reducir la exposición a reclamos por daños.

La evaluación de riesgos implica la evaluación sistemática de los riesgos y el impacto potencial que pueden tener en la investigación de evidencia digital. Los aspectos a considerar durante la evaluación de riesgos para evidencia digital potencial incluyen, pero no se limitan a los siguientes:

- ☐ ¿Qué tipo de métodos de recolección / adquisición se aplicarán?
- ☐ ¿Cuál es el equipo que se puede necesitar en el sitio?
- ☐ ¿Cuál es el nivel de volatilidad de los datos y la información relacionados con la evidencia digital potencial?
- ☐ ¿Es posible el acceso remoto a cualquier dispositivo digital y representa una amenaza para la integridad probatoria?
- ☐ ¿Qué sucede si los datos / equipos están dañados?
- ☐ ¿Se podrían haber comprometido los datos?
- ☐ ¿Podría el dispositivo digital haber sido configurado para destruir (por ejemplo, usando una bomba lógica), estropear u ofuscar datos si se apaga o se accede de forma incontrolada?

6.3 Funciones y responsabilidades

El papel del DEFR implica la identificación, recolección, adquisición y preservación de evidencia digital potencial en la escena del incidente. Incluye el desarrollo de un informe de recopilación y adquisición, pero no necesariamente el informe de análisis. El papel del DEFR también implica garantizar la integridad y autenticidad de la evidencia digital potencial. En el cumplimiento de su función, el DEFR debe tener experiencia, habilidades y conocimientos adecuados para manejar evidencia digital potencial. Esto es crucial porque la evidencia digital potencial se puede estropear fácilmente.

El DEFR también podría requerir asistencia del personal de soporte técnico en áreas relacionadas. El papel de un DES implica proporcionar soporte técnico al DEFR para identificar, recopilar, adquirir y preservar evidencia digital potencial en la escena del incidente. El DES proporciona experiencia especializada al DEFR. La matriz de competencias para el DEFR (ver Anexo A) sirve como guía para identificar sus niveles de competencia relevantes.

NOTA En el contexto del manejo de incidentes donde existe un ISIRT, los roles de un DEFR y / o DES como miembro del equipo de ISIRT se discuten en ISO / IEC 27035: 2011.

6.4 Competencia

El DEFR y / o el DES deben tener las competencias técnicas y legales relevantes (por ejemplo, las del Anexo A) y deben ser capaces de demostrar que están debidamente capacitados y tienen suficiente conocimiento técnico y legal para manejar la evidencia digital potencial de manera adecuada. Esto incluye una comprensión de los procesos y métodos apropiados para el manejo de posibles fuentes de evidencia digital. Una capacitación adecuada permitirá a los DEFR manejar dispositivos digitales que contengan evidencia digital potencial. Tener el mejor conjunto de herramientas no garantizará la calidad de la evidencia digital si el DEFR no es competente para realizar las tareas.

Algunas jurisdicciones han prescrito cómo los DEFR deben establecer sus calificaciones. Es responsabilidad de los DEFR asegurarse de que estén debidamente informados sobre cómo hacer esto en las jurisdicciones relevantes. Cuando sea necesario, el DEFR y / o el DES deberían poder demostrar que son competentes para manejar evidencia digital potencial utilizando las herramientas y métodos seleccionados para realizar las tareas. También se requiere que los DEFR puedan proporcionar evidencia de su competencia continua.

Algunos de los requisitos previos para el DEFR son los siguientes:

- ☐ Deben estar capacitados de manera adecuada y adecuada para manejar dispositivos digitales en el contexto de la investigación ocupaciones;
- ☐ Deben demostrar y mantener sus habilidades y competencia ante las autoridades apropiadas en el área relevante de manejo de evidencia digital potencial; y
- ☐ Es responsabilidad de la (s) persona (s) y el empleador asegurar que estén adecuadamente capacitados y que se mantengan las habilidades y competencias.

NOTA La competencia de un DEFR puede variar de una jurisdicción a otra.

6.5 Use cuidado razonable

Evite cualquier acción que pueda conducir a la pérdida de evidencia digital potencial que se almacena en dispositivos digitales debido a acciones intencionales o no intencionales. Por ejemplo, la exposición a campos magnéticos puede estropear la evidencia digital potencial contenida en los medios de almacenamiento magnético. El DEFR no debe acceder a dispositivos digitales, como realizar un volcado de memoria desde un dispositivo digital en vivo, a menos que tengan la competencia requerida y con el uso de procesos confiables y validados.

Hay algunas circunstancias en las que no es práctico recopilar o adquirir evidencia digital potencial. El DEFR debe considerar las siguientes circunstancias, pero no se limita solo a estas:

- ☐ Si no hay derecho legal o autorización para recoger el dispositivo digital;
- ☐ Si existe la obligación de utilizar otros métodos (por ejemplo, para evitar la interrupción de un negocio);
- ☐ Si el DEFR desea capturar el método de operación de un sospechoso durante el abuso de un sistema;
- ☐ Si la recolección o adquisición debe realizarse de forma encubierta, si la jurisdicción lo considera legal;
- ☐ Si se trata de un dispositivo digital de misión crítica que no puede tolerar ningún tiempo de inactividad;
- ☐ Si el tamaño físico del dispositivo digital es demasiado grande, como un servidor en un centro de datos o sistema RAID;
- ☐ Si es un dispositivo digital crítico para la seguridad que pondría en peligro la vida si se detuviera; y
- ☐ Si es un dispositivo digital que también presta servicios a personas inocentes.

6.6 Documentación

La documentación es crítica cuando se manejan dispositivos digitales que pueden contener evidencia digital potencial. El DEFR debe cumplir con los siguientes puntos durante la documentación:

□ Toda actividad realizada debe documentarse. Esto es para garantizar que no se hayan omitido detalles durante los procesos de identificación, recolección, adquisición y preservación. También puede ser útil en una investigación transfronteriza en la que la evidencia digital potencial reunida de otra parte del mundo se pueda rastrear en consecuencia.

DE El DEFR debe ser sensible a la configuración de fecha y hora si los dispositivos digitales están encendidos. Compare la configuración de hora con una fuente de tiempo confiable, como una hora que esté sincronizada con una fuente de tiempo confiable y rastreada. Estas configuraciones de tiempo deben documentarse y anotarse si hay diferencias presentes. Algunos sistemas requieren mucha interacción del usuario para obtener la configuración de hora y fecha. El DEFR debe tener cuidado de no modificar el sistema. Solo personal debidamente capacitado debe recuperar esta configuración.

DE El DEFR debe documentar cualquier cosa visible en la pantalla del dispositivo digital: programas y procesos activos, así como los nombres de los documentos abiertos. Esta documentación debe incluir una descripción de lo que es visible ya que algunos programas maliciosos pueden enmascarse como software conocido.

□ Cualquier movimiento de los dispositivos digitales debe documentarse de acuerdo con los requisitos locales.

□ Documente todos los identificadores únicos de los dispositivos digitales y las partes asociadas, como los números de serie y las marcas únicas.

En el Anexo B se muestran ejemplos de un conjunto mínimo de documentación para el intercambio entre jurisdicciones de evidencia digital potencial.

NOTA Consulte la cláusula de gestión de documentos y la cláusula de gestión de registros de ISO / IEC 17025: 2005 para obtener más información sobre la documentación.

6.7 Instrucciones

6.7.1 General

Es esencial que la autoridad competente informe adecuadamente al DEFR y al DES antes de realizar sus tareas, respetando las leyes y restricciones de confidencialidad (es decir, la necesidad de conocer las bases). Es importante tener una sesión informativa formal para comprender el incidente, qué esperar y qué no esperar durante la investigación, y un recordatorio contra la manipulación o despojo de evidencia. La sesión informativa debería ser suficiente para que los miembros estén bien preparados en el desempeño de sus funciones y responsabilidades; asegurando así la extracción de toda la evidencia digital potencial relevante.

6.7.2 Evidencia digital específica

Se necesita una sesión informativa que se centre explícitamente en la guía específica de evidencia digital para informar a los DEFR sobre los detalles relacionados con la investigación. Durante la sesión informativa, el DEFR y el DES deben recibir información relevante e instrucciones detalladas relacionadas con la evidencia digital potencial que se debe recopilar o adquirir. Esto puede incluir:

□ Tipo de incidente (si se conoce);

- ☐ Fecha y hora del incidente (si se conoce);
- ☐ Plan de investigación (recopilación y / o adquisición, actividad de red conocida, requisito de datos volátiles conocidos,

etc.);

- ☐ Considerar dónde y cómo se almacena / transporta la evidencia digital potencial después de la recolección o adquisición; ☐ Herramientas específicas necesarias para adquirir la evidencia digital potencial;

Evidencia digital potencial que se relaciona con tipos específicos de investigación;

- ☐ Equipos y manuales relacionados con dispositivos digitales;
- ☐ Recordar a los miembros del equipo que apaguen cualquier capacidad Bluetooth o Wi-Fi en sus teléfonos / computadoras para que no interactúen inadvertidamente con los dispositivos digitales, excepto los teléfonos / computadoras utilizados para detectar las conexiones.
- ☐ Importancia de la documentación a lo largo de la investigación; y
- ☐ Factores legales u otros factores aplicables que pueden prohibir la recolección de cualquier dispositivo y la posible evidencia digital que contengan.

Esta sesión informativa específica puede formar parte de la sesión informativa general como se describe en la cláusula 6.7.1.

6.7.3 Personal específico

Se necesita una sesión informativa centrada explícitamente en la orientación específica del personal para informar a los DEFR sobre los aspectos relacionados con las partes involucradas en la investigación. Durante la sesión informativa, el equipo investigador recibirá instrucciones relacionadas con el personal. Esto puede incluir:

- ☐ Asignaciones, roles y responsabilidades de los miembros del equipo de investigación en la escena del incidente;
- ☐ Si se espera que otras autoridades (personal médico, investigadores forenses biológicos, etc.) participen en la investigación;
- ☐ Requerir a los miembros del equipo que no acepten asistencia técnica de personas no autorizadas; y
- ☐ Requerir a los miembros del equipo que sigan el procedimiento estrictamente para minimizar el riesgo de estropear evidencia digital potencial, como evitar el uso de herramientas o materiales que puedan producir o emitir electricidad estática o un campo magnético, ya que pueden dañar o destruir la evidencia digital potencial.

Esta sesión informativa específica puede formar parte de la sesión informativa general como se describe en la cláusula 6.7.1.

6.7.4 Incidentes en tiempo real

Es altamente deseable que la investigación de un incidente se planifique por adelantado, pero hay circunstancias (por ejemplo, cuando un incidente se desarrolla y se responde en tiempo real) donde la planificación completa puede no haber sido posible. En estas situaciones, se debe informar al equipo sobre las estrategias y tácticas iniciales para la investigación y permitirle desarrollar nuevas estrategias y tácticas en respuesta a las condiciones prevalecientes. La información sobre el incidente, a medida que se desarrolla, debe compartirse entre el equipo lo más rápido posible para garantizar que las decisiones sobre las acciones a tomar se puedan tomar de manera eficiente y con la debida atención a la necesidad de justificación.

6.7.5 Otra información informativa

Además de la evidencia digital y el personal, otra información importante para informar a los equipos de investigación incluye:

- ☐ Designación del área bajo investigación, incluyendo el nombre de la organización, dirección y un mapa de ubicación (si está disponible);
- ☐ mandato de investigación;
- ☐ Detalles de las órdenes de allanamiento y otras autoridades aplicables a la investigación, incluidos los límites de la búsqueda y la incautación;
- ☐ Aspectos legales e implicaciones;
- ☐ Plazo de investigación;

El equipo necesitaba ser llevado a la escena del incidente para la investigación.;

- ☐ Información logística; y
- ☐ Posible conflicto de intereses.

El DEFR debe evitar situaciones donde se puedan hacer acusaciones de sesgo inherente. Un ejemplo de sesgo inherente es cuando un DEFR copia una computadora y no otra (que luego resulta que contiene evidencia exculpatória) basada en una percepción formada por la sesión informativa.

6.8 Priorización de cobranza y adquisición

Al priorizar la recopilación o adquisición de evidencia digital potencial, es imperativo que el DEFR comprenda la razón por la cual la evidencia digital potencial se está recolectando o adquiriendo. Como principio general, el DEFR debe intentar maximizar la cantidad de datos preservados por las acciones de recopilación y adquisición. Sin embargo, puede ser necesario priorizar los elementos por volatilidad y / o relevancia / valor probatorio potencial. Los elementos de alta relevancia / valor probatorio potencial son aquellos que tienen más probabilidades de contener datos relacionados directamente con el incidente investigado.

La priorización por volatilidad solo es aplicable si las circunstancias específicas del caso investigado lo requieren. La evidencia digital potencial se puede dividir en dos categorías: volátil y no volátil. Los datos volátiles pueden destruirse o perderse fácilmente para siempre si no se aplica el debido cuidado para proteger los datos. Por ejemplo, quitar la fuente de

alimentación de un dispositivo digital puede provocar la pérdida de datos volátiles. Los datos no volátiles permanecen en los medios incluso si se retira la fuente de alimentación. Dado que algunos tipos de evidencia digital pueden tener una vida útil corta, la evidencia digital potencial puede ser manipulada o estropeada fácilmente. Cuando no está claro si los dispositivos digitales contienen evidencia digital potencial, o qué elementos son más relevantes que otros, puede ser necesario examinarlos antes de la recolección utilizando un proceso para determinar la prioridad. Los dispositivos digitales para ser considerados para la recolección incluyen, pero no están limitados a; Equipos informáticos y medios de almacenamiento digital, sistemas de CCTV, PED, sistemas automotrices, sistemas de control y electrónica improvisada. Adquiera primero la evidencia digital potencial más volátil, como RAM, espacio de intercambio, procesos en ejecución, etc. El DEFR debe poseer un conocimiento sólido para priorizar según la volatilidad.

Tras la identificación, el DEFR debe:

- ☐ Priorizar la evidencia digital potencial que se perdería para siempre si se corta la fuente de alimentación; y
- ☐ Tome medidas rápidas para recopilar y adquirir estos datos con métodos validados.

NOTA 1 Algunos datos volátiles pueden cambiar debido a factores que incluyen, entre otros, la ubicación, la hora y los cambios en los dispositivos digitales circundantes; asegúrese de que dichos datos se conserven antes de mover el dispositivo.

NOTA 2 Los dispositivos digitales que contienen evidencia digital potencial pueden ser una fuente de evidencia física (por ejemplo, huellas digitales, ADN, etc.). Los DEFR deben tener cuidado de no estropear dicha evidencia y coordinarse con los recolectores de evidencia relevantes antes de continuar con las siguientes actividades.

NOTA 3 Cuando se sospecha cifrado o malware, es conveniente examinar los datos volátiles.

En estas circunstancias, el tiempo puede ser un factor limitante durante una investigación. En estos casos, se debe dar preferencia a la evidencia digital potencial identificada como relevante para el incidente específico.

6.9 Preservación de evidencia digital potencial

6.9.1 Descripción general

Para preservar la evidencia digital potencial adquirida y los dispositivos digitales recolectados durante el empaquetado, es importante asegurar estos artículos de una manera que elimine la despojo o la manipulación. El despojo puede ser consecuencia de la degradación magnética, la degradación eléctrica, el calor, la exposición a humedad alta o baja, así como a golpes y vibraciones. La manipulación puede resultar de un acto de hacer o permitir intencionalmente cambios en la evidencia digital potencial. Por lo tanto, es crucial proteger la evidencia digital potencial de la mejor manera posible y utilizar los datos originales lo menos posible. Es importante que el DEFR esté familiarizado con los requisitos de empaque específicos de la jurisdicción relevante.

6.9.2 Preservar evidencia digital potencial

Todos los dispositivos digitales recopilados y la evidencia digital potencial adquirida deben protegerse lo más posible de pérdidas, alteraciones o despojos. La actividad más importante

en el proceso de preservación es mantener la integridad y autenticidad de la evidencia digital potencial y su cadena de custodia.

Los dispositivos digitales recopilados y la evidencia digital potencial adquirida deben almacenarse en una instalación de preservación de evidencia que aplique controles de seguridad física, como sistemas de control de acceso, sistemas de vigilancia o sistemas de detección de intrusos u otro entorno controlado para la preservación de evidencia digital. Los objetivos principales de la seguridad física son proteger y prevenir pérdidas, daños y alteraciones, así como permitir la auditabilidad.

El (los) dispositivo (s) digital (es) recolectado (s) deben envolverse o colocarse en un embalaje apropiado para la naturaleza del dispositivo para evitar la contaminación del (los) dispositivo (s) digital (es) antes de transportarlo a otra (s) ubicación (es). El embalaje resistente a los golpes se puede utilizar para evitar daños físicos a cualquier componente del dispositivo (s).

DE El DEFR debe considerar la sensibilidad del dispositivo digital a la electricidad estática. Si esto le preocupa, el dispositivo debe estar asegurado en una bolsa antiestática.

Las unidades del sistema principal y las computadoras portátiles deben estar aseguradas en un contenedor apropiado para evitar la manipulación o despojo de la posible evidencia digital que pueda residir en él.

NOTA El uso de una bolsa Faraday u otro embalaje blindado de radiofrecuencia puede aumentar el consumo de la batería del teléfono móvil. Esto puede requerir la provisión de energía auxiliar al dispositivo dentro de la bolsa, si los recursos lo permiten.

6.9.3 Empaque de dispositivos digitales y evidencia digital potencial

6.9.3.1 Actividades de línea de base: empaque de evidencia digital potencial

Las actividades de línea de base deben realizarse a menos que haya una buena razón para no hacerlo. Esto también puede ser referido como las acciones mínimas a tomar. Durante el empaquetado, el DEFR debe tomar nota y abordar las siguientes actividades de referencia:

No toque la cinta magnética, sino que tome las cintas por sus estuches protectores o áreas que se sabe que no contienen datos (por ejemplo, bordes de discos ópticos). Esto solo debe hacerse si el DEFR usa guantes sin pelusa.

NOTA Las áreas específicas de los medios de almacenamiento que se sabe que no contienen datos dependen del tipo de medio. Es responsabilidad del DEFR conocer la tecnología actual y estar familiarizado con el manejo de los medios de almacenamiento.

□ Para garantizar una identificación correcta, el DEFR debe etiquetar todas las pruebas digitales potenciales. Algunas jurisdicciones tienen requisitos específicos con respecto al formato de etiquetado del material probatorio. El DEFR debe estar familiarizado y cumplir con los requisitos aplicables en el asunto en cuestión. El DEFR debe etiquetar toda evidencia digital potencial, dispositivo (s) digital (es) recolectado (s) y cualquier pieza de hardware asociada con los dispositivos con etiquetado a prueba de manipulaciones. La etiqueta no debe colocarse directamente sobre las partes mecánicas del dispositivo digital y no debe cubrir u ocultar información de identificación importante. Todas las pruebas digitales potenciales en los dispositivos recopilados deben adquirirse y almacenarse de manera que se garantice la integridad de las pruebas.

☐ Cuando sea posible, los dispositivos digitales con aberturas y componentes móviles deben sellarse con etiquetas a prueba de manipulaciones que sean apropiadas para los dispositivos, y el DEFR debe firmar en el sello.

☐ Los dispositivos que están conectados a baterías con datos volátiles deben verificarse regularmente para asegurarse de que los dispositivos siempre tengan suficiente fuente de alimentación.

☐ Identifique y asegure los dispositivos digitales en un contenedor adecuado para la naturaleza del dispositivo contra las posibles amenazas.

☐ Las computadoras y los dispositivos digitales deben empaquetarse de tal manera que eviten daños por golpes, vibraciones, gran altitud, calor y exposición a radiofrecuencia durante el transporte.

Media Los medios de almacenamiento magnéticos deben almacenarse en envases magnéticamente inertes, antiestáticos y libres de partículas.

Los dispositivos digitales también pueden contener evidencia latente, traza o biológica. Como tal, se deben realizar actividades apropiadas para preservar la evidencia digital potencial. La obtención de imágenes de evidencia digital debe realizarse después de que se realicen procesos de recolección de evidencia latente, traza o biológica en los dispositivos. Sin embargo, la decisión de priorizar la recopilación de evidencia debe evaluarse a fondo para preservar la evidencia.

6.9.3.2 Actividades adicionales: empaquetado de evidencia digital potencial

Las actividades adicionales se refieren a actividades que se recomienda realizar. Durante el empaque, el DEFR debe tomar nota y abordar las siguientes actividades adicionales, cuando corresponda:

☐ Use guantes sin pelusa y asegúrese de que las manos estén limpias y secas.

☐ Proteja los dispositivos digitales de la influencia de fuentes electromagnéticas (por ejemplo, radios policiales, altavoces, máquinas de rayos X). El entorno del embalaje debe estar libre de electricidad estática.

El entorno del embalaje debe estar libre de polvo, grasa y contaminantes químicos que promuevan el deterioro oxidativo y la condensación de humedad en la capa magnética.

☐ Minimice la posibilidad de impresión (la transferencia de una señal de un bucle de cinta a un bucle adyacente), que puede ocurrir cuando las cintas se almacenan durante largos períodos sin uso activo, lo que da como resultado una mala calidad de la señal.

☐ Donde sea necesario, las áreas de empaque deben estar libres de luz UV. Los rayos UV pueden causar degradación del ADN o dañar algunos tipos de medios. El DEFR debe considerar si los rayos UV representan un riesgo para la evidencia digital potencial antes de seleccionar un área de empaque.

☐ Los dispositivos digitales deben estar fuertemente protegidos contra el choque térmico.

6.9.4 Transporte de evidencia digital potencial

El DEFR debe preservar los dispositivos digitales recolectados y la evidencia digital potencial adquirida durante el transporte. La evidencia digital potencial no debe dejarse desatendida durante el proceso de transporte. El DEFR debe mantener la cadena de custodia durante todo el proceso de transporte para evitar posibles manipulaciones o despojos, y mantener la integridad y autenticidad de los dispositivos digitales y la posible evidencia digital. Si el DEFR o el DES no transportan la evidencia digital potencial, se recomienda utilizar cifrado.

NOTA El DEFR debe garantizar que la recopilación de información confidencial o personal esté de acuerdo con las leyes y regulaciones jurisdiccionales locales sobre protección de datos.

Durante el embalaje y el transporte, el DEFR debe ser consciente de la posible presencia de descarga electrostática que puede dañar el valor probatorio de la posible evidencia digital. El DEFR debe garantizar que las computadoras y los dispositivos digitales estén embalados de forma segura durante el transporte para evitar daños por golpes y vibraciones.

El proceso de transporte debe permitir un ambiente propicio y controlado. El nivel de humedad, humedad y temperatura debe ser adecuado para los dispositivos digitales. Evite mantener posibles pruebas digitales y dispositivos digitales en el vehículo de transporte durante períodos prolongados y evite que estén en presencia de rayos UV.

En algunas jurisdicciones, cuando las circunstancias no lo permiten, el DEFR no puede acompañar la evidencia. En tales casos, se puede utilizar la utilización de mecanismos de envío apropiados y autorizados para garantizar la seguridad adecuada de la evidencia durante el transporte. Los documentos del transporte y la verificación de la integridad del paquete deben formar parte de la cadena de custodia.

7. Instancias de identificación, recolección, adquisición y conservación.

7.1 Computadoras, dispositivos periféricos y medios de almacenamiento digital.

7.1.1 Identificación

7.1.1.1 Búsqueda y documentación de la escena del incidente físico

En el contexto de esta cláusula, las computadoras se consideran dispositivos digitales independientes que reciben, procesan y almacenan datos y producen resultados. Estos dispositivos informáticos no están conectados a una red, pero pueden estar conectados a dispositivos periféricos como impresoras, escáneres, cámaras web, reproductores de MP3, sistemas GPS, dispositivos RFID, etc. Un dispositivo digital que tiene una interfaz de red, pero que no está conectado en el momento de la recolección o adquisición, debe considerarse (para los fines de esta Norma Internacional) como una computadora independiente. Cuando una computadora con una interfaz de red, pero no se encuentra una conexión obvia, se deben realizar actividades para identificar dispositivos a los que se haya conectado en el pasado reciente.

Por lo general, las escenas de incidentes contendrán varios tipos de medios de almacenamiento digital. Los medios de almacenamiento digital se utilizan para almacenar datos de dispositivos digitales y varían en capacidad de memoria. Los ejemplos de medios de almacenamiento digital incluyen, entre otros, discos duros portátiles externos, unidades flash, CD, DVD, discos Blu-ray, disquetes, cintas magnéticas y tarjetas de memoria.

Antes de poder realizar cualquier adquisición o recopilación, se deben considerar los aspectos de seguridad de la evidencia digital potencial. Estos aspectos se describen en las cláusulas 6.2.1 y 6.2.2. Sin embargo, el DEFR debe asegurarse de asegurarse de que un dispositivo aparentemente independiente no se haya conectado recientemente a una red. Cuando se sospeche que un dispositivo aparentemente independiente se ha desconectado recientemente, se debe considerar tratarlo como un dispositivo en red para garantizar que otras partes de la red se manejen correctamente. El DEFR debe tener en cuenta y abordar al menos lo siguiente:

DE El DEFR debe documentar el tipo y la marca de cualquier dispositivo digital utilizado e identificar todas las computadoras y dispositivos periféricos que puedan necesitar ser adquiridos o recolectados durante esta etapa inicial. Los números de serie, los números de licencia y otras marcas de identificación (incluido el daño físico) deben documentarse siempre que sea posible.

□ En la etapa de identificación, el estado de las computadoras y los dispositivos periféricos debe permanecer como está. Si las computadoras o los dispositivos periféricos están apagados, no los encienda. Si las computadoras o los dispositivos periféricos están encendidos, el DEFR no debe apagarlos, ya que de lo contrario podría estropear la evidencia digital potencial.

□ Si las computadoras están encendidas, el DEFR debe fotografiar o hacer un documento escrito de lo que se muestra en las pantallas. Cualquier documento escrito debe incluir una descripción de lo que es realmente visible (por ejemplo, posiciones aproximadas de ventanas, títulos y contenidos).

□ Un dispositivo que tiene baterías que pueden agotarse debe cargarse para garantizar que no se pierda información. El DEFR necesita identificar y recolectar posibles cargadores de batería y cables durante esta fase.

□ El DEFR también debe considerar el uso de un detector de señal inalámbrica para detectar e identificar señales inalámbricas de dispositivos inalámbricos que puedan estar ocultos. Puede haber casos en los que no se use un detector de señal inalámbrico debido a limitaciones de costo y tiempo y el DEFR debería documentarlo. Si se encuentran dispositivos en red, el DEFR debe continuar con el proceso de manejo de evidencia como se describe en la cláusula 7.2.2.2 de este documento. Cuando se va a utilizar el escaneo activo (es decir, la transmisión y / o el sondeo) para dispositivos de red, los dispositivos de escaneo deben estar apagados hasta que se haya determinado la posibilidad de que el dispositivo interactúe con otros dispositivos en la escena. Los miembros del equipo deben recordar que ciertos dispositivos en la escena pueden detectar la presencia de dispositivos de escaneo activos y el uso del escaneo activo puede desencadenar acciones que pueden estropear la evidencia digital potencial y, en circunstancias extremas, puede provocar la activación de trampas ocultas.

NOTA 1 En algunas jurisdicciones, está permitido encender dispositivos digitales en una escena para determinar su relevancia para la investigación si hay muchos dispositivos digitales presentes. Esto se hace teniendo en cuenta el tiempo de procesamiento y el costo en el que se puede incurrir si se adquieren dispositivos digitales no relevantes. Si se enciende un dispositivo para su evaluación en la escena, el DEFR debe garantizar que se mantengan notas detalladas de las acciones tomadas durante el proceso.

NOTA 2 Al preservar el estado de energía del dispositivo digital, se deben considerar los resultados de la volatilidad y el proceso de priorización relevante. Si se toma la decisión de

que la información más crítica es la información no volátil en el disco, entonces el sistema en ejecución puede fotografiar la pantalla de la consola y desconectar el enchufe de alimentación. Si la información volátil en la memoria es relevante, entonces es crítico dejar el sistema encendido para permitir su adquisición.

7.1.1.2 Recolección de evidencia no digital

El DEFR debería considerar la recopilación de evidencia no digital. Para permitir esto, el líder del equipo debe identificar a las personas responsables de las instalaciones en la escena. Esta persona puede proporcionar información adicional y documentación, como contraseñas a los dispositivos digitales y otros detalles relevantes. El DEFR necesita documentar el nombre y la designación de este individuo.

Es posible que el DEFR también necesite recopilar alguna evidencia hablando con personas que puedan tener información útil o relevante sobre la evidencia digital potencial o los dispositivos digitales que se recopilarán. Cualquier respuesta debe documentarse con precisión. Estas personas pueden incluir el administrador del sistema, el propietario del dispositivo y los usuarios de la computadora y los dispositivos periféricos. Durante esta recopilación de evidencia verbal, el DEFR puede solicitar información como la configuración del sistema y la contraseña de administrador / root. Esta información adicional puede ser útil en la etapa de análisis de la evidencia digital potencial. Estas conversaciones deben documentarse para garantizar que los detalles sean precisos y que la declaración documentada no se pueda cambiar. El DEFR debe estar familiarizado con los requisitos jurisdiccionales relevantes para la recolección de evidencia no digital.

7.1.1.3 Proceso de toma de decisiones para la recolección o adquisición

Al decidir recolectar un dispositivo digital o adquirir evidencia digital potencial, se deben considerar varios factores que incluyen, entre otros, los siguientes:

- ☐ volatilidad de la evidencia digital potencial que se discutió en las cláusulas 5.4.2 y 6.8,
- ☐ existencia de cifrado de disco completo o volúmenes cifrados donde la frase de contraseña o las claves pueden residir como datos volátiles en RAM, en tokens externos, tarjetas inteligentes, otros dispositivos o medios,
- ☐ criticidad del sistema que se discutió en las cláusulas 5.4.4, 7.2.1.2 y 7.1.3.4,
- ☐ requisitos legales de una jurisdicción, y
- ☐ recursos tales como el tamaño de almacenamiento requerido, disponibilidad de personal, limitaciones de tiempo.

La Figura 1 ilustra la visión general del proceso de toma de decisiones para hacer la recolección o adquisición.

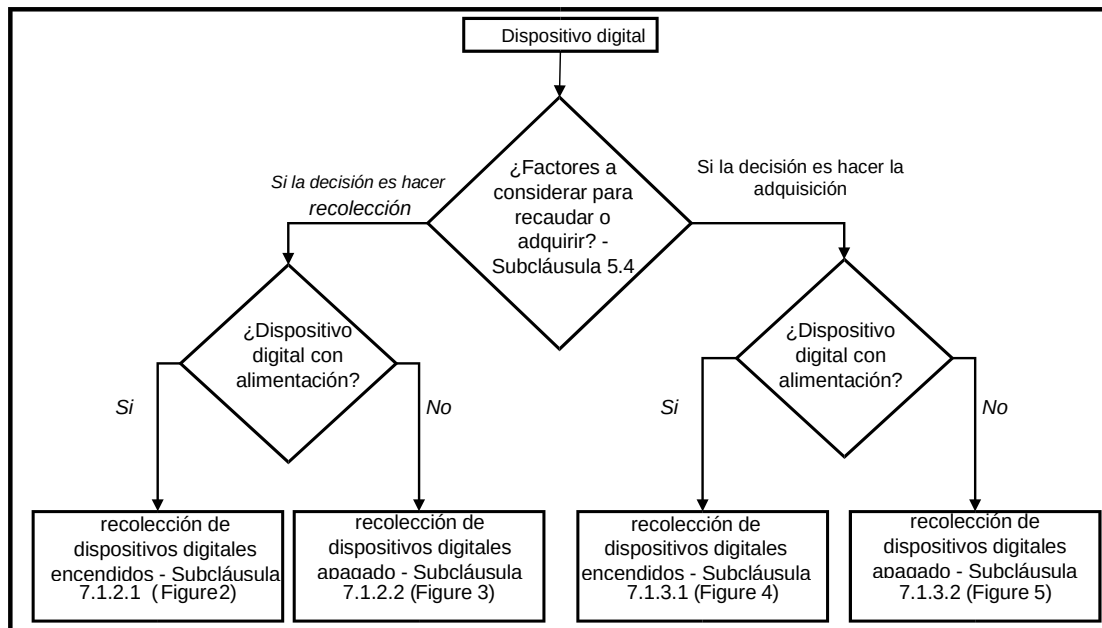


Figura 1 — Pautas para la toma de decisiones de recopilación o adquisición de evidencia digital potencial

7.1.2 Recolección

7.1.2.1 Alimentado en dispositivos digitales

7.1.2.1.1 Descripción general

El DEFR puede seguir una serie de pautas para la recolección cuando el dispositivo digital está encendido. No todas las pautas son ideales y apropiadas para cualquier caso; Algunas pautas solo son relevantes para casos específicos. En consecuencia, las pautas se pueden clasificar como basales o adicionales. Las actividades de línea de base deben aplicarse en todas las circunstancias, mientras que las actividades adicionales deben aplicarse cuando sea relevante y aplicable, según el dispositivo o las circunstancias únicas. La Figura 2 ilustra la línea base y las actividades adicionales aplicables a la recolección de dispositivos digitales encendidos.

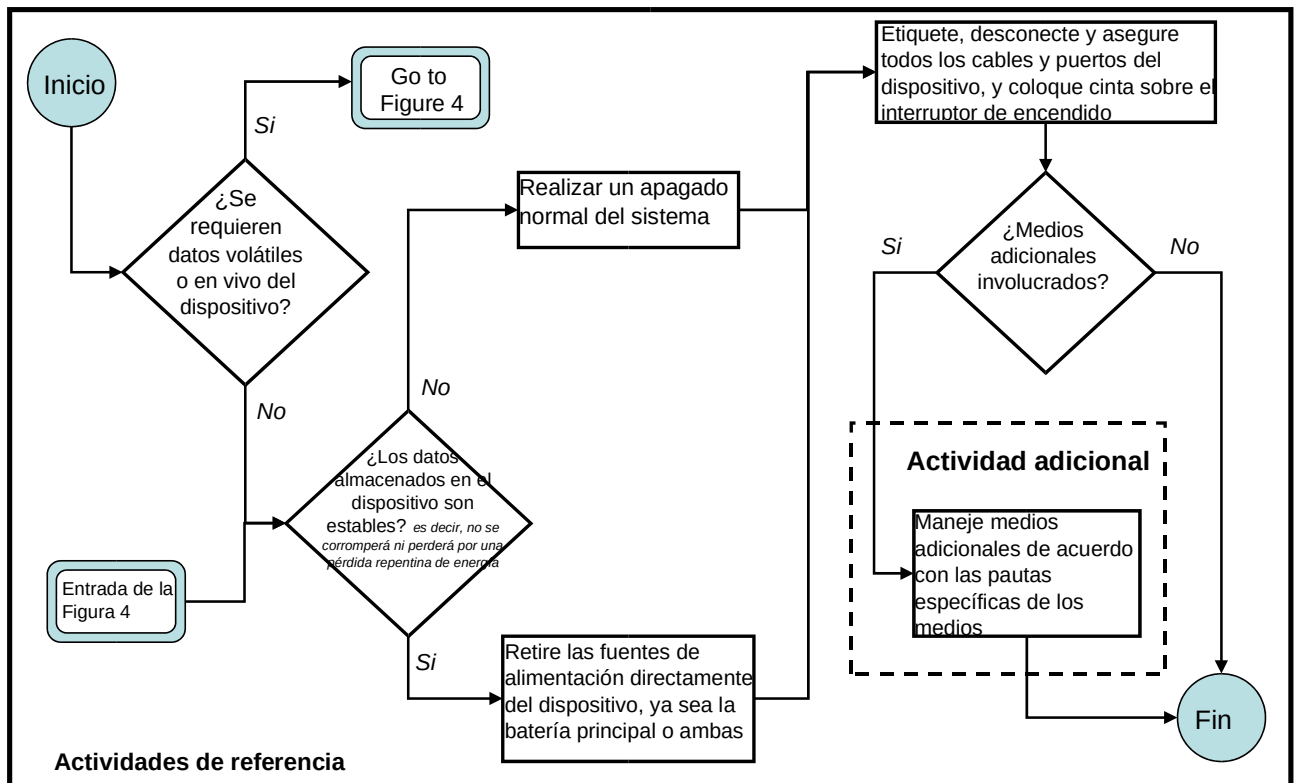


Figura 2 — Pautas para la recolección de dispositivos digitales encendidos

NOTA Todas estas actividades deben estar de acuerdo con las leyes y regulaciones jurisdiccionales locales.

Es responsabilidad del DEFR conocer la tecnología actual y estar familiarizado con las pautas de manejo de medios de almacenamiento.

7.1.2.1.2 Actividades de referencia: recolección de dispositivos digitales con alimentación

El DEFR debe seguir las siguientes actividades de línea de base en todos los casos que involucren evidencia digital potencial. Estas pautas se aplican cuando el DEFR ha decidido que se debe recopilar un dispositivo digital encendido:

- Considere la adquisición de los datos volátiles del dispositivo digital y el estado actual antes de apagar el sistema. Las claves de cifrado y otros datos cruciales pueden residir en la memoria activa o en la memoria inactiva que aún no se ha borrado. Considere la adquisición lógica cuando se sospeche el cifrado. Si este es el caso, tenga en cuenta que el sistema operativo del host en vivo puede no ser confiable, por lo tanto, considere el uso de herramientas confiables y validadas apropiadas.
- La configuración del dispositivo digital puede determinar si el DEFR necesita apagar el dispositivo mediante procedimientos administrativos normales, o si el enchufe del dispositivo debe ser desconectado de la toma de corriente. El DEFR puede necesitar consultar con un DES para determinar el mejor enfoque dadas las circunstancias específicas. Si se toma la decisión de desconectar el enchufe, el DEFR necesita quitar el cable de alimentación quitando primero el extremo conectado al dispositivo digital y no el extremo conectado al

enchufe. Tenga en cuenta que un dispositivo conectado a un UPS puede tener datos alterados si el cable de alimentación se retira de la pared y no el dispositivo.

NOTA 1 Si se desconecta la alimentación de un dispositivo digital encendido, cualquier evidencia digital potencial almacenada en volúmenes cifrados será inaccesible, a menos que se obtenga la clave de descifrado. Los datos en vivo potencialmente valiosos también podrían perderse, lo que llevaría a reclamos por daños o pérdida de vidas humanas, como datos corporativos o dispositivos digitales que controlan equipos médicos. Como tal, el DEFR debe garantizar que se recopilen datos volátiles antes de retirar la fuente de alimentación.

NOTA 2 Existen dispositivos de hardware que permiten que el dispositivo encendido se desconecte de la red eléctrica y se transfiera a un UPS portátil sin interrumpir la alimentación del dispositivo. También hay mouse que pueden usarse para evitar que se active el protector de pantalla. Ambos dispositivos proporcionan herramientas útiles cuando se trata de un dispositivo encendido donde el cifrado puede estar activo. Cuando se recolecta un dispositivo encendido de manera que se mantiene la energía, el embalaje y el transporte de un sistema en funcionamiento deben abordar los problemas asociados con la provisión de refrigeración, protección contra descargas mecánicas, etc.

☐ Etiquete, desconecte y asegure todos los cables del dispositivo digital y etiquete los puertos para que el sistema pueda reconstruirse en una etapa posterior.

☐ Coloque cinta sobre el interruptor de alimentación si es necesario para evitar que el interruptor cambie de estado. Considere si el estado del interruptor se ha documentado correctamente antes de grabar o mover.

7.1.2.1.3 Actividades adicionales: recolección de dispositivos digitales con alimentación

Las siguientes son actividades adicionales que son relevantes dependiendo de la configuración del dispositivo digital específico.

☐ Si se trata de una computadora portátil, asegúrese de adquirir los datos volátiles antes de quitar la batería. El DEFR debe quitar primero la batería de la fuente de alimentación principal, en lugar de presionar el botón de encendido de la computadora portátil para apagarla. El DEFR también debe tomar nota si hay un adaptador de corriente y, si lo está, retire el adaptador de corriente después de quitar la batería.

NOTA 1 La acción de presionar el botón de encendido en un dispositivo digital puede configurarse para iniciar una secuencia de comandos que pueda alterar la información o eliminar información del sistema antes de apagar o alertar a los sistemas conectados de que se ha producido un evento inesperado para que puedan borrar los datos de valor probatorio antes de que se identifiquen. También se puede configurar para activar un dispositivo destinado a causar daño físico al DEFR y a otras personas presentes.

☐ Coloque la cinta sobre la ranura del disquete, si está presente.

☐ Asegúrese de que las bandejas de la unidad de CD o DVD estén retraídas en su lugar; observe si estas bandejas de unidades están vacías, contienen discos o no están marcadas; y tape la ranura de la unidad para evitar que se abra.

NOTA 2 Si queda algún medio de arranque cuando la máquina se vuelva a encender, podría arrancar desde ese medio en lugar del disco duro (o unidad flash de herramientas forenses) dependiendo de la configuración del BIOS de la computadora.

El DEFR debe realizar la recolección de evidencia no digital de acuerdo con las leyes de procedimiento para garantizar que cualquier evidencia sea admisible.

7.1.2.2 Apagado de dispositivos digitales

7.1.2.2.1 Descripción general

El DEFR puede seguir una serie de pautas para la recolección cuando el dispositivo digital está apagado. No todas las actividades contenidas en estas pautas son relevantes en todas las circunstancias. Por lo tanto, se debe hacer una distinción entre aquellas actividades que se aplican en todos los casos (actividades de referencia) y aquellas que solo pueden aplicarse en algunos casos (actividades adicionales).

La Figura 3 ilustra la línea base y las actividades adicionales aplicables a la recolección de dispositivos digitales apagados.

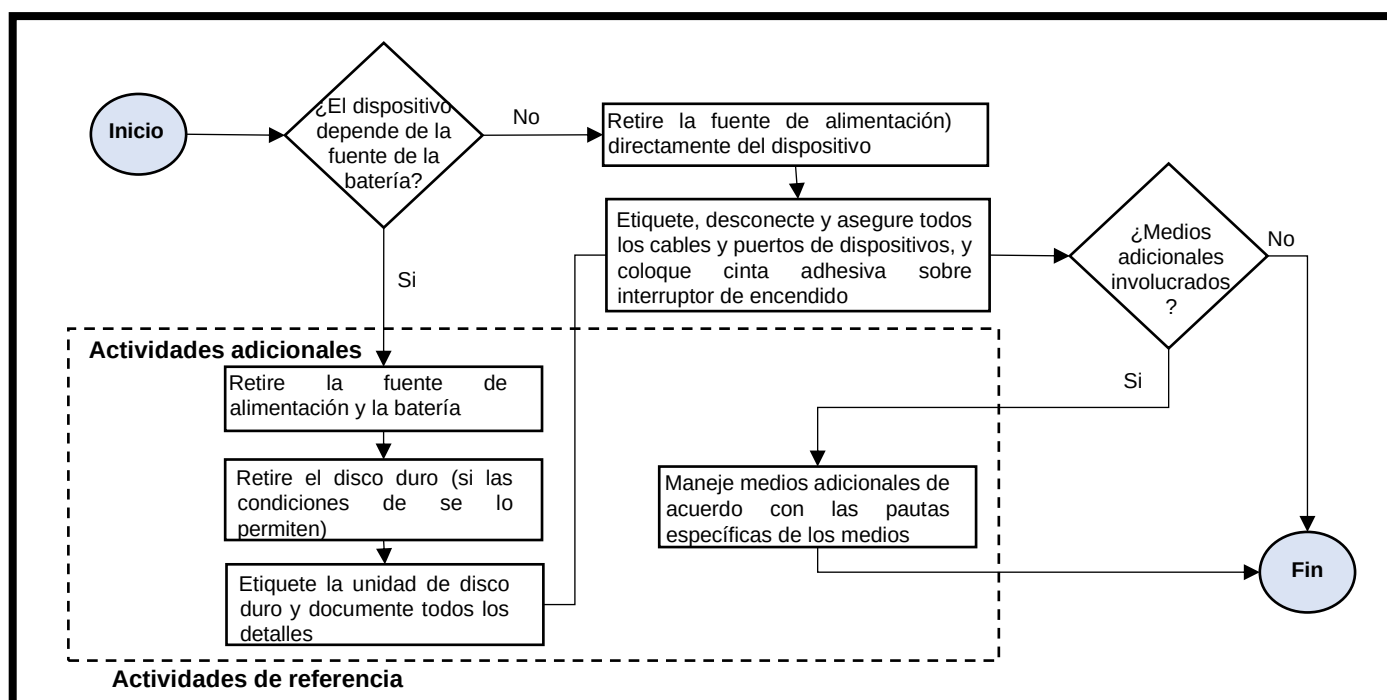


Figura 3: Pautas para la recolección de dispositivos digitales apagados

Es responsabilidad del DEFR conocer la tecnología actual y estar familiarizado con las pautas de manejo de medios de almacenamiento.

7.1.2.2.2 Actividades de referencia: recolección de dispositivos digitales apagados

Las siguientes son las actividades de referencia recomendadas para la recolección cuando el dispositivo digital está apagado:

- Retire el cable de alimentación quitando primero el extremo conectado al dispositivo digital y no el extremo conectado al zócalo.

- ☐ Desconecte y asegure todos los cables de los dispositivos digitales y etiquete los puertos para que el sistema pueda reconstruirse en una etapa posterior.
- ☐ Coloque cinta sobre el interruptor de alimentación si es necesario para evitar que el interruptor cambie de estado. Considere si el estado del interruptor se ha documentado correctamente antes de grabar o mover.

NOTA En la mayoría de los casos, los medios de almacenamiento no se deben quitar del dispositivo digital hasta que se vayan a adquirir, ya que su extracción aumenta el riesgo de dañarlos o confundirlos con otros medios de almacenamiento. Deben desarrollarse y seguirse los procedimientos locales sobre la necesidad de eliminar los medios de almacenamiento de los dispositivos digitales.

7.1.2.2.3 Actividades adicionales: recolección de dispositivos digitales apagados

Las siguientes son actividades adicionales que son relevantes para la recolección de dispositivos digitales apagados, dependiendo de la configuración del dispositivo digital específico:

- ☐ Primero, asegúrese de que la computadora portátil esté apagada, ya que algunas pueden estar en modo de espera. Tenga en cuenta que algunas computadoras portátiles se pueden encender abriendo la tapa. Luego, retire la batería de la fuente de alimentación principal de la computadora portátil.
- ☐ Si las condiciones de campo requieren que se extraiga el disco duro, el DEFR debe asegurarse de conectar a tierra el dispositivo digital para evitar que la electricidad estática dañe el disco duro. De lo contrario, el disco duro no debe extraerse en el campo. Etiquete el disco duro como disco sospechoso y documente todos los detalles, como la marca, el nombre del modelo, el número de serie y el tamaño del disco duro.
- ☐ Coloque la cinta sobre la ranura del disquete, si está presente.
- ☐ Asegúrese de que las bandejas de la unidad de CD o DVD estén retraídas en su lugar; observe si estas bandejas de unidades están vacías, contienen discos o no están marcadas; y tape la ranura de la unidad para evitar que se abra.

NOTA Si queda algún medio de arranque cuando la máquina se enciende la próxima vez, podría arrancar desde ese medio en lugar del disco duro (o unidad flash de herramientas forenses) dependiendo de la configuración del BIOS de la computadora.

7.1.3 Adquisición

7.1.3.1 Alimentado en dispositivos digitales

7.1.3.1.1 Descripción general

Existen tres escenarios en los que puede ser necesario realizar la adquisición: cuando los dispositivos digitales están encendidos, cuando los dispositivos digitales están apagados y cuando los dispositivos digitales están encendidos, pero no pueden apagarse (como los dispositivos digitales de misión crítica). En todos estos escenarios, el DEFR debe hacer una copia de evidencia digital precisa de los medios de almacenamiento de los dispositivos digitales que se sospecha que contienen evidencia digital potencial.

Si no se puede obtener una imagen, se pueden adquirir copias precisas de archivos específicos sospechosos de contener evidencia digital potencial. Idealmente, se deben producir tanto una copia maestra verificada como copias de trabajo. La copia maestra no se debe volver a utilizar a menos que se requiera verificar el contenido de la copia de trabajo o producir una copia de trabajo de reemplazo después de dañar la primera copia de trabajo.

El DEFR puede seguir una serie de pautas para la adquisición cuando se encuentra que el dispositivo digital está encendido. No todas las pautas son ideales y apropiadas para todos los casos; Algunas pautas solo son relevantes para casos específicos. En consecuencia, las pautas se pueden clasificar como basales o adicionales. Debe tenerse en cuenta la posibilidad de que un sistema encendido pueda entrar en modo de protector de pantalla o bloqueo automático y que existan implicaciones en cualquier esfuerzo realizado para evitarlo. Por ejemplo, el uso de un mouse requerirá una entrada de llave USB en el registro y las modificaciones probablemente se realizarán para cualquier acción que se tome. El uso de métodos confiables debería minimizar las implicaciones de tales acciones. La Figura 4 ilustra la línea base y las actividades adicionales aplicables a la adquisición de dispositivos digitales encendidos.

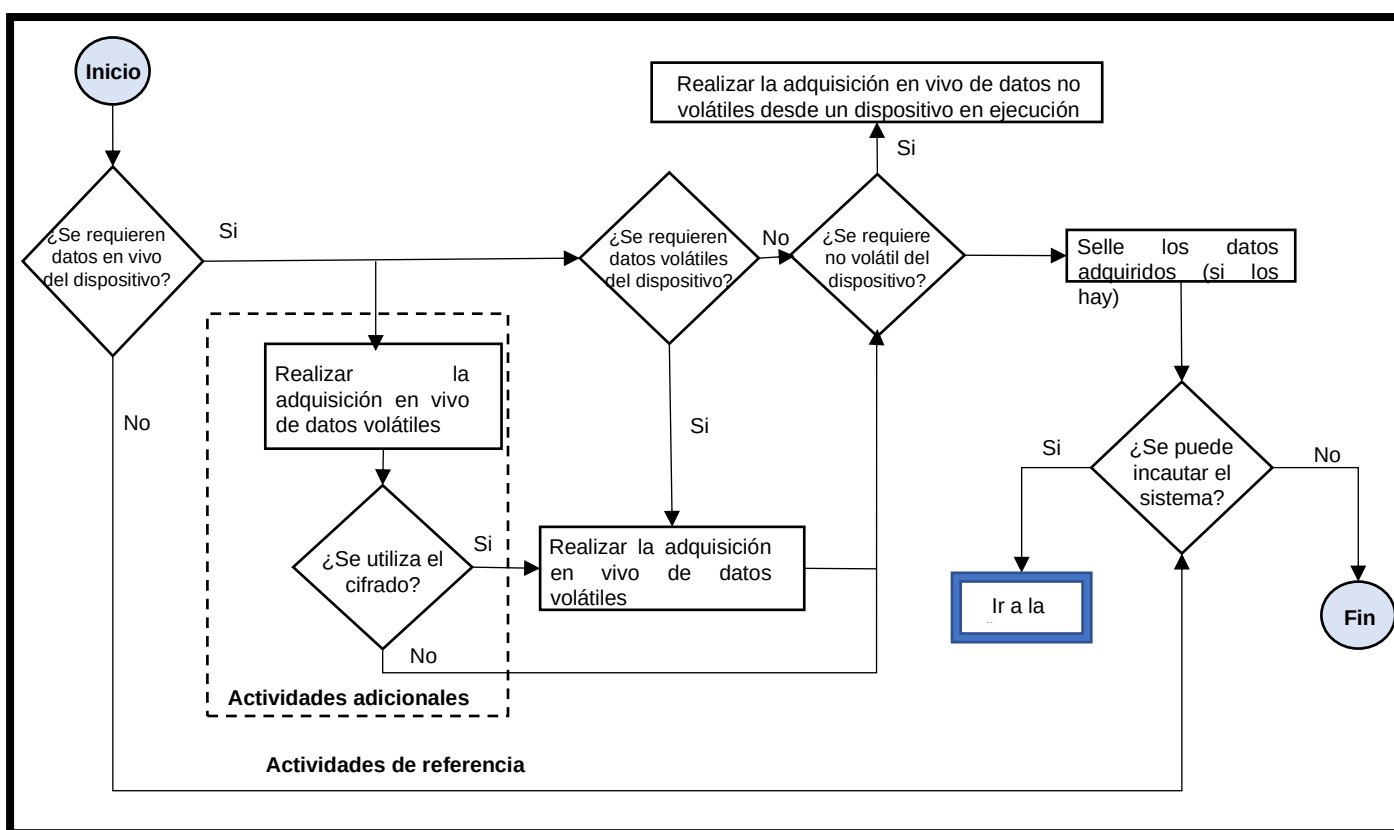


Figura 4: Pautas para la adquisición de un dispositivo digital encendido

7.1.3.1.2 Actividades de línea de base: adquisición de dispositivos digitales activados

A continuación, se detallan las actividades de base que DEFR debe seguir en todos los casos que involucren la adquisición potencial de evidencia digital en dispositivos digitales encendidos:

□ Primero, considere adquirir la evidencia digital potencial que de otro modo se perdería si el dispositivo digital está apagado. Esto también se conoce como datos volátiles, como datos

almacenados en la RAM, procesos en ejecución, conexiones de red y configuraciones de fecha / hora. En circunstancias en las que es necesario adquirir datos no volátiles de dispositivos que aún se están ejecutando, se debe considerar realizar una adquisición en un sistema encendido.

□ Es necesario realizar una adquisición en vivo para adquirir datos en vivo de dispositivos que aún se están ejecutando. La adquisición en vivo de datos volátiles en RAM puede permitir la recuperación de información valiosa, como el estado de la red, la aplicación descifrada y las contraseñas. La adquisición en vivo se puede realizar en la consola o de forma remota a través de la red. Los procesos son diferentes y requieren el uso de un conjunto diferente de herramientas.

DE El DEFR nunca debe confiar en los programas en los sistemas. Por esta razón, se recomiendan herramientas confiables obtenidas por el DEFR (binarios estáticos) siempre que sea posible. El DEFR debe ser competente para usar herramientas validadas y ser competente para tener en cuenta los efectos que dichas herramientas pueden tener en el sistema (por ejemplo, el desplazamiento de evidencia digital potencial, el contenido de la memoria que se busca cuando se carga el software, etc.). Todas las acciones realizadas y los cambios resultantes realizados a la evidencia digital potencial deben documentarse y comprenderse. Si no es posible determinar el efecto probable de introducir herramientas en el sistema o los cambios resultantes no pueden determinarse con certeza, esto también debe documentarse.

□ Al adquirir datos volátiles, el DEFR debería adoptar el uso de un contenedor de archivos lógicos cuando sea posible y documentar su valor hash una vez que contenga los archivos de datos volátiles. Cuando esto no sea posible, se debe usar un contenedor como un archivo ZIP y luego este archivo se debe codificar y el valor debe documentarse. Los contenedores de archivos resultantes deben almacenarse en un medio de almacenamiento digital que se haya preparado para este propósito, es decir, formateado.

□ Ejecute el proceso de imágenes en el almacenamiento no volátil en vivo utilizando una herramienta de imágenes validada. La copia de evidencia digital resultante debe almacenarse en un medio de almacenamiento digital que se haya preparado para este propósito. Si bien es preferible utilizar un nuevo medio de almacenamiento digital, el uso de copias de evidencia digital de procesos validados garantiza la integridad de los datos cuando se reconstruyen. Por lo tanto, un medio de almacenamiento digital que haya sido desinfectado será suficiente. Si la imagen tiene que almacenarse en un contenedor de archivos lógicos, el DEFR debe garantizar que la imagen no pueda corromperse o dañarse.

NOTA En situaciones en las que el dispositivo está bloqueado, el acceso físico puede realizarse a través de otros medios que tengan habilitado el acceso directo a la memoria, p. Ej. Interfaz Firewire

7.1.3.1.3 Actividades adicionales: adquisición de dispositivos digitales activados

Las siguientes son actividades adicionales que son relevantes para la adquisición de dispositivos digitales encendidos, dependiendo de la configuración del dispositivo digital específico:

□ Considere la adquisición de datos volátiles en RAM cuando se sospeche el uso de cifrado. Primero verifique si este puede ser el caso inspeccionando el disco sin procesar o utilizando alguna utilidad de detección criptográfica. Si este es el caso, tenga en cuenta que el sistema

operativo del host en vivo puede no ser confiable y considere el uso de herramientas adecuadas confiables y validadas.

- ☐ Use una fuente de tiempo confiable y documente el tiempo de cada acción realizada.
- ☐ Puede ser apropiado asociar el DEFR con la evidencia digital potencial adquirida, utilizando firmas digitales, biometría y fotografía.

NOTA La acción de presionar el botón de encendido en un dispositivo digital puede configurarse para iniciar un script que puede alterar la información y / o eliminar información del sistema antes de apagar o alertar a los sistemas conectados de que se ha producido un evento inesperado para que puedan borrar datos de valor probatorio antes de ser identificados. También se puede configurar para activar un dispositivo destinado a causar daño físico al DEFR y a otras personas presentes.

7.1.3.2 Apagado de dispositivos digitales

7.1.3.2.1 Descripción general

Es más fácil manejar un dispositivo digital apagado en comparación con un dispositivo digital encendido porque no hay necesidad de adquirir los datos volátiles. La Figura 5 ilustra las actividades que son aplicables a la adquisición de dispositivos digitales apagados.

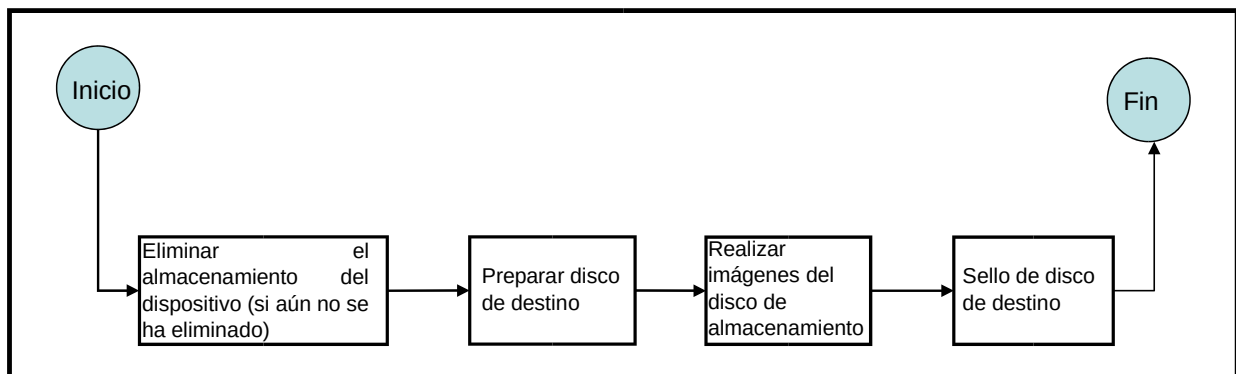


Figura 5 - Pautas para la adquisición de un dispositivo digital apagado

7.1.3.2.2 Adquisición de dispositivo digital apagado

Las siguientes son las actividades de adquisición cuando se encuentra que el dispositivo digital está apagado:

- ☐ Asegúrese de que el dispositivo esté apagado.
- ☐ Si corresponde, elimine el almacenamiento del dispositivo digital apagado si aún no se ha eliminado. Etiquete el almacenamiento como almacenamiento sospechoso y documente todos los detalles, como la marca, el nombre del modelo, el número de serie y el tamaño del almacenamiento.
- ☐ Ejecute el proceso de imágenes utilizando una herramienta de imágenes validada para crear una copia de evidencia digital del disco sospechoso.

NOTA En la mayoría de los casos, los medios de almacenamiento no se deben quitar del dispositivo digital hasta que se vayan a adquirir, ya que su extracción aumenta el riesgo de daños o de confundirlos con otros medios de almacenamiento. Deben desarrollarse y seguirse procedimientos locales relacionados con la necesidad de extraer discos duros.

7.1.3.3 Dispositivos digitales de misión crítica

En algunos casos, los dispositivos digitales no se pueden apagar debido a la naturaleza crítica de los sistemas. Estos sistemas, como los servidores de los centros de datos que también podrían prestar servicios a clientes inocentes, sistemas de vigilancia, sistemas médicos y muchos otros que pueden verse gravemente afectados si se interrumpen o se apagan. Se debe tener especial cuidado al tratar con tales sistemas.

Cuando el dispositivo digital no se pueda apagar, realice una adquisición en vivo y / o parcial, como se describe en las cláusulas 7.1.3.1.2 y 7.1.3.4.

7.1.3.4 Adquisición parcial

La adquisición parcial puede realizarse debido a varias razones, tales como:

- ☐ el almacenamiento del sistema es demasiado grande para ser adquirido (por ejemplo, servidor de base de datos);
- ☐ un sistema es demasiado crítico para apagarse;
- ☐ cuando solo los datos seleccionados para ser adquiridos contienen otros datos irrelevantes dentro del mismo sistema; o
- ☐ cuando está limitado por la autoridad legal, como una orden de allanamiento que limita el alcance de la adquisición.

Cuando se ha tomado la decisión de realizar una adquisición parcial, las actividades de adquisición deben incluir, entre otras, las siguientes:

- ☐ Identifique la (s) carpeta (s), archivo (s) o cualquier opción relevante del sistema patentado disponible para adquirir los datos deseados,
- ☐ Realizar una adquisición lógica en los datos identificados.

7.1.3.5 Medios de almacenamiento digital

Se pueden encontrar varios tipos de medios de almacenamiento digital en una escena del incidente. Por lo general, estos son los tipos de datos menos volátiles y pueden ser la prioridad más baja durante la recopilación y adquisición. Esto no significa que no sean importantes porque, en muchos casos, los medios de almacenamiento digital externos contienen la evidencia que buscan los analistas. El DEFR debe garantizar lo siguiente:

- ☐ Verifique y documente la ubicación (por ejemplo, bahía de unidad, cable y conector, ranura USB, etc.), marca, modelo y número de serie (si corresponde) de cada medio de almacenamiento digital encontrado.
- ☐ Decidir si recolectar los medios de almacenamiento digital identificados o realizar una adquisición en el sitio, la decisión debe basarse en la naturaleza del incidente y los recursos

disponibles. Para realizar la adquisición in situ de los medios de almacenamiento digital (principalmente el disco duro), consulte la Figura 4.

☐ Si el DEFR decide y se le permite recolectar medios de almacenamiento digital, los medios recolectados deben envolverse o colocarse en el embalaje apropiado.

☐ Etiquete todos los medios de almacenamiento digital y cualquier parte asociada con ellos. Las etiquetas de evidencia no deben colocarse directamente en las partes mecánicas de los medios digitales, ni deben cubrir u ocultar información importante como el número de serie, el número de modelo y el número de parte. Todos los medios recopilados deben adquirirse y almacenarse de manera que se garantice la integridad de los medios recopilados. Cuando sea posible, la evidencia debe sellarse con sellos a prueba de manipulaciones y el DEFR o el personal a cargo deben firmar en la etiqueta.

Media Los medios de almacenamiento digital recopilados deben almacenarse en un entorno adecuado para la preservación de datos.

☐ Los diferentes medios de almacenamiento digital tienen diferentes capacidades de retención de datos. El DEFR debe tener en cuenta el período de tiempo máximo aceptable especificado por la jurisdicción pertinente, con respecto a las capacidades de retención de datos de los medios de almacenamiento digital.

7.1.4 Preservación

Una vez que se completa el proceso de adquisición, el DEFR debe sellar los datos adquiridos utilizando funciones de verificación o firmas digitales para determinar que las copias de evidencia digital son equivalentes a los originales. Además, los aspectos de seguridad requieren controles que apliquen los principios de preservar la confidencialidad, integridad y disponibilidad de la evidencia digital potencial. Con el fin de proteger contra la espiración, los aspectos ambientales deben abordarse con las medidas apropiadas. El DEFR debe garantizar lo siguiente:

☐ Utilice una función de verificación apropiada para proporcionar evidencia de que los archivos copiados son equivalentes a los originales.

☐ Puede ser apropiado asociar el DEFR con la evidencia digital potencial adquirida, utilizando firmas digitales, biometría y fotografía.

Todos los dispositivos digitales que se recolectaron deben conservarse adecuadamente. Los diferentes tipos de dispositivos digitales pueden requerir diferentes métodos de conservación. La evidencia digital potencial necesita ser preservada a lo largo de su vida útil, que puede variar según las jurisdicciones y la política de la organización.

NOTA Como alternativa al sellado de los datos adquiridos con funciones de verificación o firmas digitales, el DEFR también puede usar características biométricas. La biometría utiliza características físicas y de comportamiento para determinar la identidad de un individuo. Al adjuntar una característica biométrica a la evidencia adquirida, puede garantizar que la evidencia no pueda ser manipulada sin comprometer la característica biométrica.

7.2 Dispositivos en red

7.2.1 Identificación

7.2.1.1 Descripción general

En el contexto de esta cláusula, los dispositivos de red se consideran computadoras u otros dispositivos digitales que están conectados a una red en modo cableado o inalámbrico. Estos dispositivos en red pueden incluir mainframes, servidores, computadoras de escritorio, puntos de acceso, conmutadores, concentradores, enrutadores, dispositivos móviles, PDA, PED, dispositivos Bluetooth, sistemas de CCTV y muchos más. Tenga en cuenta que, si los dispositivos digitales están conectados en red, es difícil determinar dónde se almacena la evidencia digital potencial que se busca. Los datos podrían ubicarse en cualquier lugar de la red.

La identificación de un dispositivo digital incluye componentes como logotipos del fabricante, números de serie, bases y adaptadores de corriente. El DEFR puede considerar los siguientes aspectos como un medio de identificación:

Características del dispositivo: la marca y el fabricante de un dispositivo digital a veces se pueden identificar por sus características observables, particularmente si existen elementos de diseño únicos.

Interface Interfaz del dispositivo: el conector de alimentación a menudo es específico de un fabricante y es una ayuda confiable para la identificación.

Etiqueta del dispositivo: para dispositivos móviles apagados, la información obtenida desde el interior de la cavidad de la batería puede ser reveladora, particularmente cuando se combina con una base de datos adecuada. Por ejemplo, el IMEI es un número de 15 dígitos que indica el fabricante, el tipo de modelo y el país de aprobación de los dispositivos GSM; El ESN es un identificador único de 32 bits documentado en un chip seguro en un teléfono móvil por el fabricante: los primeros 8-14 bits identifican al fabricante y los bits restantes identifican el número de serie asignado.

□ Búsqueda inversa: en el caso de los teléfonos móviles, si se conoce el número de teléfono del teléfono, se puede utilizar una búsqueda inversa para identificar al operador de la red.

Debido al pequeño tamaño general de los dispositivos móviles, el DEFR debe tener especial cuidado para identificar todos los tipos de dispositivos móviles que puedan ser relevantes para el caso. El DEFR debe asegurar la escena del incidente sospechoso y garantizar que ninguna persona retire el dispositivo móvil ni ningún otro dispositivo digital de la escena. Los dispositivos digitales que pueden contener evidencia digital deben protegerse del acceso no autorizado.

NOTA En algunos casos, la comunicación no debe interrumpirse. Informar a las personas autorizadas sobre posibles problemas (por ejemplo, no advertir a personas desconocidas sobre el dispositivo de apagado).

7.2.1.2 Búsqueda y documentación de la escena del incidente físico.

Antes de que se pueda realizar una adquisición o recolección, la escena del incidente debe documentarse de manera visual, ya sea fotografiando, grabando en video o dibujando la escena tal como apareció a la entrada. La elección del método de documentación debe equilibrarse con las circunstancias, el costo, el tiempo, los recursos disponibles y las prioridades. El DEFR debe documentar todos los demás elementos en la escena que pueden contener materiales potencialmente relevantes, como notas garabateadas, notas adhesivas, diarios, etc.

DE El DEFR debe documentar el tipo, la marca, el modelo y los números de serie de cualquier dispositivo digital utilizado e identificar todos los dispositivos digitales que puedan necesitar ser adquiridos o recopilados durante esta etapa inicial. Todos los dispositivos móviles y sus elementos asociados, como tarjetas de memoria, tarjetas SIM, cargadores y soportes que se encuentran en la escena, sus números de serie asociados y cualquier característica de identificación deben documentarse y recopilarse, si es necesario. También intente encontrar el embalaje original de los teléfonos móviles; Estos pueden contener notas con códigos PIN y PUK.

□ Si el dispositivo está conectado en red, el DEFR debe identificar los servicios prestados por los dispositivos para comprender las dependencias y determinar la importancia de los dispositivos dentro de la red antes de decidir desconectar el dispositivo de la red. Esto es importante si los dispositivos cumplen funciones de misión crítica que no pueden tolerar ningún tiempo de inactividad o evitar la destrucción de evidencia digital potencial. Sin embargo, si parece haber amenazas continuas basadas en la red a los dispositivos, el DEFR puede necesitar decidir desconectar el dispositivo de la red para proteger la posible evidencia digital.

□ Si el dispositivo en red es un sistema de CCTV, el DEFR debe anotar la cantidad de cámaras conectadas al sistema, así como también cuáles de estas cámaras están operando activamente. El DEFR también debe tener en cuenta la marca, el modelo y la configuración básica del sistema, como la configuración de visualización, la configuración de registro actual y la ubicación de almacenamiento, de modo que, si se deben realizar cambios para facilitar el proceso de recolección y adquisición, entonces es posible devolver el sistema a su estado original.

□ En la medida de lo posible, el estado de los dispositivos digitales debe permanecer como está. En general, si los dispositivos digitales están apagados, el DEFR no debe encenderlos y si están encendidos, el DEFR no debe apagarlos. Esto puede evitar el despojo innecesario de evidencia digital potencial. Un dispositivo que tiene baterías que pueden agotarse debe cargarse para garantizar que no se pierda información. El DEFR necesita identificar posibles medios de carga y cable durante esta fase. Si un dispositivo se va a transportar y examinar en una fecha futura indeterminada, puede ser apropiado apagarlo para minimizar el potencial de daño a los datos contenidos en el dispositivo.

DE El DEFR también debe considerar el uso de un detector de señal inalámbrica para detectar e identificar una señal inalámbrica de dispositivos inalámbricos que pueda estar oculta. Puede haber casos en los que el detector de señal inalámbrica no se use debido a limitaciones de costo y tiempo y el DEFR debe documentar esto.

7.2.2 Recolección, adquisición y conservación.

7.2.2.1 Visión de conjunto

El DEFR necesita decidir si recolectar o adquirir la evidencia digital potencial de los dispositivos digitales. La elección debe equilibrarse con las circunstancias, el costo, el tiempo, los recursos disponibles y las prioridades.

Si el DEFR decidió desconectar los dispositivos, el proceso para recopilar o adquirir la evidencia digital potencial seguirá como se describe en la cláusula 5.4. En el caso de que los dispositivos no puedan desconectarse de la red debido a la importancia de su función o la probabilidad de destrucción de evidencia digital potencial, el DEFR debe realizar la adquisición en vivo mientras los dispositivos permanecen conectados a la red.

NOTA Es fundamental contar con procedimientos sólidos y estándar que empleen herramientas validadas, junto con una buena documentación y un DEFR capacitado y con experiencia.

La recopilación y adquisición de evidencia digital potencial de dispositivos móviles en red es complicada porque pueden existir en múltiples estados y modos de interacción como Bluetooth, radiofrecuencia, pantalla táctil e infrarrojo. Además, diferentes fabricantes de dispositivos móviles utilizan diferentes tipos de sistemas operativos, lo que requiere diferentes métodos de adquisición de evidencia. También hay una amplia gama de tarjetas de memoria que se usan con dispositivos móviles, y quitar estas tarjetas de memoria de los dispositivos móviles encendidos podría interferir con los procesos en ejecución.

En general, los dispositivos móviles como PDA y teléfonos móviles deben encenderse para adquirir evidencia digital potencial. Estos dispositivos pueden alterar continuamente su entorno operativo mientras están encendidos, por ejemplo, el temporizador del reloj se puede actualizar. El problema asociado es que dos copias de evidencia digital del mismo dispositivo pueden no pasar las funciones de verificación estándar como el hash. En esta situación, las funciones de verificación alternativas que identifican áreas de coincidencia y / o diferencia pueden ser más apropiadas.

Es importante que el DEFR no introduzca dispositivos Wi-Fi o Bluetooth en la escena que puedan cambiar la información de emparejamiento en posibles dispositivos probatorios. Esto es particularmente importante si el investigador necesita saber qué dispositivos se han conectado.

Si el DEFR decidió seguir un proceso de adquisición, los dispositivos de red deben mantenerse en funcionamiento para un análisis posterior para determinar los otros dispositivos conectados a los dispositivos de red. El DEFR debe considerar la posibilidad de sabotaje por parte del sospechoso a través de una conexión de red activa y decidir monitorear el sistema o desconectarse.

7.2.2.2 Pautas para la recopilación de dispositivos en red

En algunas circunstancias, puede ser apropiado dejar los dispositivos en red conectados para que su actividad pueda ser monitoreada y documentada por un DEFR y / o DES con la autoridad apropiada. Cuando esto no sea necesario, los dispositivos deben recogerse como se describe a continuación:

DE El DEFR debe aislar el dispositivo de la red, cuando es seguro que esta acción no sobrescribirá los datos relevantes y no se produce un mal funcionamiento en sistemas importantes (como los sistemas de administración de instalaciones en hospitales). Esto se puede hacer desconectando las conexiones de red cableadas al sistema telefónico o al puerto de red, o deshabilitando la conexión al punto de acceso inalámbrico.

□ Antes de desconectar las redes cableadas, el DEFR debe rastrear las conexiones a los dispositivos digitales y etiquetar los puertos para la reconstrucción futura de toda la red. Un dispositivo puede tener más de un método de comunicación. Por ejemplo, una computadora puede tener LAN cableadas, un módem inalámbrico y tarjetas de teléfonos móviles. Los PED también se pueden conectar a la red a través de Wi-Fi, conexiones Bluetooth o conexiones de red de telefonía móvil. El DEFR debe intentar identificar todos los métodos de comunicación y realizar actividades apropiadas para proteger contra la destrucción de evidencia digital potencial.

□ Tenga en cuenta que la eliminación de energía de los dispositivos en red en este punto puede destruir datos volátiles, como procesos en ejecución, conexiones de red y datos almacenados en la memoria. El sistema operativo del host puede no ser confiable e informar información falsa. El DEFR debe capturar esta información utilizando métodos verificados confiables antes de quitar la energía de los dispositivos. Una vez que el DEFR esté seguro de que no se perderá evidencia digital potencial como resultado, se pueden eliminar las conexiones de los dispositivos digitales.

□ Si la recolección tiene prioridad sobre la adquisición y se sabe que el dispositivo contiene memoria volátil, el dispositivo debe estar conectado continuamente a una fuente de alimentación.

□ Si el dispositivo móvil está apagado, empaque, selle y etiquete cuidadosamente el dispositivo. Esto es para evitar cualquier operación accidental o deliberada de las teclas o botones. Como precaución, DEFR también debe considerar el uso de las cajas protegidas o Faraday.

□ En algunas circunstancias, los dispositivos móviles deben apagarse durante la recopilación para evitar que se modifiquen los datos. Esto puede suceder a través de conexiones o comandos salientes y entrantes que pueden causar la destrucción de evidencia digital potencial.

□ Posteriormente, cada dispositivo digital puede tratarse como si fuera un dispositivo independiente (consulte la cláusula 7.1) hasta que se examine. Durante el examen, debe considerarse como un dispositivo en red.

NOTA Es posible implementar una forma de red utilizando dispositivos de almacenamiento extraíbles como medios de transmisión. El DEFR debe considerar si los dispositivos que se están recolectando pueden haberse utilizado de esta manera y buscar información sobre los otros dispositivos en una red de este tipo.

7.2.2.3 Pautas para la adquisición de dispositivos en red

En la situación en la que los dispositivos están conectados a una red, existe la posibilidad de que los dispositivos estén conectados a más de una (1) red física y / o virtual. Por ejemplo, un dispositivo que parece tener una (1) conexión de red física visible puede, de hecho, ejecutar una red privada virtual (VPN) y una máquina virtual con más de una (1) dirección IP. Como tal, antes de desconectar el dispositivo de la red, el DEFR debe realizar la adquisición lógica de datos relacionados con la conexión de red lógica (por ejemplo, conectividad a Internet). Los datos relacionados incluyen, entre otros, la configuración de IP y las tablas de enrutamiento.

Para que un dispositivo de red deba estar encendido continuamente, se debe evitar que el dispositivo interactúe con la red de radio inalámbrica, incluidos los dispositivos habilitados para GPS. El DEFR debe usar métodos permitidos por la ley local para aislar las señales de radio. Sin embargo, se debe tener cuidado para garantizar que el dispositivo tenga una fuente de alimentación adecuada, ya que los métodos de aislamiento pueden hacer que use energía adicional en un intento de contactar una red. Los métodos de aislamiento pueden incluir, entre otros, los siguientes:

□ Usar un dispositivo de interferencia que pueda bloquear la transmisión mediante la creación de fuertes interferencias cuando el dispositivo emite señales en el mismo rango de frecuencia que usan los dispositivos móviles.

NOTA 1 El uso de dispositivos de interferencia puede violar los requisitos legales en algunas jurisdicciones.

NOTA 2 El uso de dispositivos de interferencia puede afectar negativamente el comportamiento de dispositivos electrónicos como equipos médicos.

☐ Usar un área de trabajo blindada para realizar exámenes de forma segura en un lugar fijo. El blindaje se puede hacer para toda el área de trabajo o mediante la instalación de una carpa Faraday que permita la portabilidad. Sin embargo, alimentar cables dentro de la tienda es problemático, ya que sin un aislamiento adecuado pueden comportarse como una antena, lo que anula el propósito de la tienda. El espacio de trabajo también puede ser muy restrictivo.

☐ Usar un área de trabajo blindada para realizar exámenes de forma segura en un lugar fijo. Se puede usar un espacio de trabajo o contenedor blindado de radiofrecuencia (una jaula de Faraday) para evitar conexiones a la red.

NOTA 3 Todos los métodos para bloquear el acceso inalámbrico a las redes deben validarse para su uso en las frecuencias apropiadas. Esta validación debe extenderse a los cables que pasan a través del blindaje.

☐ Usar un SIM (U) sustituto que imita la identidad del dispositivo original y evita el acceso a la red por parte del dispositivo. Estas tarjetas pueden engañar al dispositivo para que las acepte como la SIM (U) original y permiten que los exámenes se realicen de forma segura en cualquier lugar. La (U) SIM debe validarse para el dispositivo y la red antes de su uso.

☐ Deshabilite los servicios de red acordando con el proveedor de servicios móviles e identificando detalles sobre los servicios a deshabilitar (por ejemplo, el identificador del equipo, el identificador del suscriptor o el número de teléfono). Sin embargo, dicha información no siempre está disponible cuando el proceso de coordinación y confirmación puede imponer demoras.

El DEFR puede realizar la adquisición en vivo del dispositivo móvil antes de quitar la batería (por ejemplo, para acceder a la tarjeta SIM). Esto se puede hacer para evitar la pérdida de información importante potencial en la memoria RAM del teléfono o para acelerar el proceso de examen (por ejemplo, cuando se cree que el dispositivo puede estar protegido por un PIN y / o PUK que requeriría una cantidad significativa de tiempo para obtener).

NOTA 4 El DEFR debe garantizar que la recopilación y adquisición de evidencia digital potencial esté de acuerdo con las leyes y regulaciones jurisdiccionales locales, según se requiera según las circunstancias específicas.

7.2.2.4 Directrices para la preservación de dispositivos en red

Debido a la naturaleza de los dispositivos digitales y la evidencia digital potencial, las pautas para la preservación de los dispositivos en red son similares a la preservación de las computadoras, los dispositivos periféricos y los medios de almacenamiento digital. Consulte la cláusula 7.1.4 para obtener instrucciones detalladas sobre la preservación del dispositivo.

7.3 Recolección, adquisición y preservación de CCTV

El DEFR debe entender que el enfoque para extraer secuencias de video de un sistema de CCTV DVR integrado o basado en computadora es diferente de la extracción de evidencia digital convencional de una computadora. A continuación, se presentan pautas específicas para la adquisición de evidencia digital potencial de los sistemas de CCTV:

□ Antes de que comience el proceso de adquisición, el DEFR debe determinar primero si el sistema documentó la secuencia de video de interés. Posteriormente, el DEFR debe determinar el período de tiempo del metraje de video requerido y comparar la hora del sistema con la hora correcta y anotar cualquier compensación. El DEFR también debe determinar qué cámaras se requieren y si se pueden adquirir por separado. El DEFR debe tener en cuenta la marca y modelo del sistema. Esta información puede ser necesaria para obtener el software de reproducción correcto.

DE El DEFR debe adquirir todas las grabaciones de cámara relevantes durante el tiempo de interés para preservar información de investigación adicional que pueda desarrollarse más tarde. El DEFR debe tener en cuenta todas las cámaras conectadas a un sistema de CCTV y determinar si están grabando activamente o no.

El DEFR debe determinar el tamaño de almacenamiento del sistema de CCTV, así como cuándo está programado que el sistema sobrescriba la información del video. Esta información le permitirá al DEFR saber cuánto tiempo se mantendrá la secuencia de video en el sistema antes de que se pierda. Se deben tomar medidas para garantizar que no se modifique la evidencia. Para evidencia de video digital, la protección contra escritura debe estar en su lugar.

□ Hay algunas opciones que el DEFR puede elegir para adquirir evidencia digital potencial de los sistemas de CCTV:

1) Adquiera los archivos de video escribiéndolos en un disco CD / DVD / Blu-ray, pero esto puede no ser práctico si el archivo de video es demasiado grande.

2) Adquiera los archivos de video escribiéndolos en un medio de almacenamiento externo.

3) Adquiera los archivos de video a través de una conexión de red. Esto puede estar disponible si el sistema de CCTV está equipado con un puerto de red.

4) Use la función de exportación del sistema de CCTV a otros formatos de archivo (generalmente MPEG o AVI), que es una versión comprimida del metraje de video. Esto solo debe usarse como último recurso, ya que la recompresión altera los datos originales y siempre elimina los detalles de la imagen. No se recomienda confiar en los datos recomprimidos para su examen si los datos originales existen y están disponibles para su análisis.

NOTA 1 La calidad del metraje de video exportado puede no ser tan buena como el metraje original.

5) Cuando no sea posible adquirir directamente una copia de evidencia digital de los archivos en el dispositivo de grabación, el DEFR o DES debe intentar adquirir una copia analógica de la salida analógica presente en el dispositivo de grabación original utilizando un dispositivo de grabación analógico adecuado.

□ Al completar la adquisición, se debe verificar el archivo adquirido para confirmar que se ha adquirido el archivo correcto o la parte correcta del archivo. El archivo también debe verificarse con el software del reproductor (para formatos de archivos de dispositivos digitales) para su reproducción en otros sistemas: la mayoría de los sistemas de CCTV son propietarios y los archivos no pueden reproducirse necesariamente utilizando otro software del reproductor. El software de reproducción correcto puede estar disponible para descargar del sistema de CCTV al mismo tiempo que los datos.

□ El medio de almacenamiento digital que contiene el archivo adquirido debe tratarse como la copia maestra de evidencia digital. Si el archivo se ha descargado en una computadora portátil o en una tarjeta de memoria / dispositivo USB, se debe hacer una copia maestra permanente de estos tan pronto como sea posible.

□ Posteriormente, el DEFR debería reiniciar el sistema de CCTV si estaba apagado. Esto debe hacerse en presencia de la persona autorizada.

En circunstancias donde no es práctico llevar a cabo la adquisición en el lugar, el DEFR puede decidir recolectar los medios de almacenamiento digital. Un método rápido es reemplazar el disco duro del sistema de CCTV con un disco duro en blanco o clonado. Sin embargo, el DEFR debe evaluar varios riesgos antes de usar este método, como la compatibilidad del nuevo disco duro con el sistema y la compatibilidad del disco duro extraído con otros sistemas para su examen.

NOTA 2 Algunos sistemas tienen un disco duro extraíble en un carrito, pero este disco duro puede requerir el hardware del sistema para la reproducción.

Si ninguno de los métodos anteriores es posible, entonces todo el sistema de CCTV debe eliminarse de la escena y el proceso de adquisición debe llevarse a cabo nuevamente en el laboratorio forense. Este es el último recurso del DEFR y supone que es físicamente posible hacerlo porque algunos sistemas de CCTV son extremadamente grandes y complejos. Nuevamente, el DEFR debe evaluar los riesgos para las implicaciones legales y el seguro antes de la eliminación.

Debido a la naturaleza de los dispositivos digitales y la evidencia digital potencial, las pautas para la preservación de los sistemas de CCTV son similares a la preservación de las computadoras, los dispositivos periféricos y los medios de almacenamiento digital. Consulte la cláusula 7.1.4 para obtener orientación sobre la preservación del sistema de CCTV.

Anexo A (informativo)

Descripción de habilidades y competencias básicas de DEFR

Tabla A.1 - Ejemplos de descripciones de competencias

No	Habilidades fundamentales	Descripciones de habilidades básicas	Descripciones de competencias		
			Conciencia (1)	Conocimiento (2)	Habilidad (3)
1	Digital evidencia identificación	Caracterice el dispositivo digital, los componentes, la información que puede ayudar a la investigación y las leyes relevantes para el manejo de evidencia digital potencial y delitos relacionados con la computadora. Identifique los requisitos de herramientas para la recopilación y adquisición de datos y dispositivos y la evaluación de riesgos.	Usuario general de TI y administración en múltiples tipos de dispositivos de TI y dispositivos de red; procedimientos de investigación en la escena del crimen; determinación del estado del dispositivo; valor de la información probatoria; dispositivos e informaciones forenses relacionados con la red.	Registros y configuración del sistema / aplicación; identificación de registros del sistema y de aplicaciones, incluidos registros de correo electrónico, registro web, registros de acceso, archivos de contraseña, archivos sysconfig, información de IP del host; funcionalidad y dependencia del dispositivo; capacidad de comprender el impacto en evidencia volátil y no volátil.	Análisis especial; interpretación de registros para la detección de intrusos en la identificación de otros sistemas afectados (algunas jurisdicciones requieren la confirmación de la evidencia presente antes de la recopilación); identificar las contraseñas requeridas para los dispositivos respectivos antes de la recopilación; identificar el diagrama de red y los mecanismos de control de acceso para comprender las dependencias; enlace las direcciones IP y las direcciones MAC para la confirmación del dispositivo.

2	Recolección de evidencia digital	Requisitos de herramientas y implementación de empaques de evidencia digital, protección contra amenazas ambientales. Las áreas cubiertas incluyen el aseguramiento de la información.	Seguridad general de la recopilación de datos; principios y diseño de herramientas básicas; determinar el mejor método de recolección para preservar máximo información relevante al incidente.	Formular y ejecutar el proceso de recolección; Recolectar evidencia; generar evidencia documentos; cadena de custodia de evidencia; control de calidad del proceso de recolección de evidencia; Entrevista sospechoso.	Optimización del proceso de recolección; documentar evidencia que no se puede adquirir debido a varias restricciones; recopilar contraseñas, claves, llaves y otra información requerida para realizar análisis en el laboratorio.
3	Adquisición de evidencia digital	Aplicar los requisitos de posible adquisición de evidencia digital en forma lógica, asegurando la repetibilidad, auditabilidad, reproducible y defendible. Las áreas cubiertas son	Comprender la información disponible en formato digital. dispositivos, bases de datos, documentos generados por el sistema, datos generados por el usuario y datos volátiles; Unix y Windows estructuras de archivos del sistema y	Sepa cómo determinar los requisitos de almacenamiento; ejecutar el procedimiento de adquisición de imágenes (p. ej. adquisición parcial y total de medios de almacenamiento digital); adquisición realizada en un sistema encendido,	Capacidad para realizar la adquisición de medios de almacenamiento digital, incluidos RAID, bases de datos, dispositivos y dispositivos miniaturizados; Comprender las dependencias y el impacto en diferentes métodos de adquisición.
No	Habilidades fundamentales	Descripciones de habilidades básicas	Descripciones de competencias		
			Conciencia (1)	Conocimiento (2)	Habilidad (3)
		adquisición realizada en un sistema encendido, adquisición realizada en un sistema apagado y	accesorios; conciencia del impacto en los datos volátiles.	adquisición realizada en un sistema apagado; generación de valor hash.	

		análisis forense de red.			
4	Preservación de evidencia digital	Aplicar y evaluar los requisitos para la preservación de la evidencia digital potencial, comprender los factores y parámetros influyendo en su precisión. Las áreas cubiertas son metodología, mantenimiento de la cadena de custodia, manejo de dispositivos informáticos y manejo de medios de almacenamiento digital.	Comprender los requisitos y procedimientos para el mantenimiento de la cadena de custodia contra los requisitos legales; impacto ambiental tal como humedad, temperatura y choque hacia dispositivo digital; Comprender las opciones de embalaje, los requisitos de transporte y almacenamiento.	Saber cómo en la generación de documentos de auditoría de evidencia; definir parámetros para documentos; garantía de seguridad de la información, amenazas, vulnerabilidad y controles para evidencia digital.	Aplicar medidas para asegurar la evidencia digital, en forma de dispositivos grandes para dispositivos de mano miniaturizados; procedimiento para documentar detalles de evidencia.

Tabla A.2 - Definición de competencia

1	Conciencia - Reconocer, identificar - preguntar cuando se necesita ayuda
2	Conocimiento: adquirido mediante capacitación formal o trabajando en equipo. Contribuir, participar - hacer con ayuda
3	Experiencia probada en habilidades a través de la aplicación en el entorno de trabajo. Trabajos sin supervisión. Aplicar, demostrar, prescindir de ayuda.

NOTA La competencia de un DEFR puede variar de una jurisdicción a otra.

Anexo B (informativo)

Requisitos mínimos de documentación para la transferencia de evidencia

El DEFR debe ser responsable de los datos adquiridos y los dispositivos digitales en todo momento mientras están bajo su custodia. Para mantener este control, el DEFR debe estar debidamente autorizado, capacitado y calificado. Sin embargo, dado que la ley local es un factor determinante en la capacidad de un DEFR para cumplir con los tres requisitos esperados, la competencia de un DEFR puede variar de una jurisdicción a otra. Como resultado, es posible que los requisitos de documentación para la transferencia de evidencia digital entre jurisdicciones no sean iguales en diferentes jurisdicciones.

En consecuencia, se debe especificar un conjunto mínimo de requisitos de documentación para facilitar el intercambio entre jurisdicciones de evidencia digital potencial. Estos requisitos de documentación deben considerarse con los puntos de documentación mencionados en la cláusula 6.6. Dado que esta Norma Internacional no reemplaza los requisitos legales específicos de ninguna jurisdicción, sirve como una guía práctica para la transferencia de evidencia digital potencial a través de las fronteras jurisdiccionales.

La documentación mínima a comunicar es:

- ☐ el nombre y la dirección de la autoridad pertinente;
- ☐ una declaración de la autorización, capacitación y calificaciones del DEFR;
- ☐ el propósito del examen;
- ☐ qué acciones se llevaron a cabo;
- ☐ quién hizo qué y cuándo;
- ☐ la cadena de custodia de la investigación específica;

Listado descriptivo de evidencia digital potencial y medios de almacenamiento digital recopilados y adquiridos; e información sobre cualquier examen, prueba o investigación utilizada para crear la copia de evidencia

Los requisitos específicos de la jurisdicción pueden incluir lo siguiente:

- ☐ si la evidencia se considera como una opinión experta, el reconocimiento del Código de Conducta de Testigos Expertos pertinente; y
- ☐ una orden judicial que especifica qué documentación debe transferirse y el motivo de la transferencia.

Bibliografía

[1] ILAC – G19: 2002. Pautas para laboratorios de ciencias forenses. Disponible de: [www.ilac.org/ documents/ g19_ 2002.pdf](http://www.ilac.org/documents/g19_2002.pdf)

[2] IOCE, G8 propuso principios para los procedimientos relacionados con la evidencia digital. Disponible de: 5 <http://ioce.org/core.php?ID=5>

ISO/IEC 15489:2001, *Información y documentación - Gestión de registros*

ISO/IEC 17024:2003, *Evaluación de la conformidad: requisitos generales para los organismos que operan certificación de personas*

ISO/IEC 17043:2010, *Evaluación de conformidad: requisitos generales para las pruebas de aptitud*

ISO/IEC 27001, *Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de seguridad de la información - Requisitos*

ISO/IEC 27002, *Tecnología de la información. Técnicas de seguridad. Sistemas de gestión de la seguridad de la información. Código de prácticas para la gestión de la seguridad de la información.*

ISO/IEC 24760-1, *Tecnología de la información. Técnicas de seguridad. Un marco para la gestión de la identidad. Parte 1: Terminología y conceptos.*

ISO/IEC 27031:2010, *Tecnología de la información. Técnicas de seguridad. Directrices para la preparación de las TIC para la continuidad del negocio.*

ISO/IEC 27035:2011, *Tecnología de la información - Técnicas de seguridad - Gestión de incidentes de seguridad de la información*

[11] *Estándares de acreditación académica y CPD de la Sociedad de Ciencias Forenses.* Disponible: <http://www.forensic-science-society.org.uk>

[12] *Directrices para la recopilación y archivo de pruebas.* Disponible de: <http://www.ietf.org/rfc/rfc3227.txt>.